SAÉ 401

Sécuriser un système d'information

Rapport d'activité

Coban — Emre — Adem — Romdhane
Formateur : Mr. ROY

Sommaire

1. Présentation du projet et planning
- 1.1. Matériel utilisé

2. Schéma réseau et plan d'adressage

3. Installation et configuration de l'infrastructure
- 3.1. Pare-feu Stormshield SN320
- 3.2. Serveur Windows Server 2022
  - Configuration réseau
  - Active Directory Domain Services
  - Service DHCP
  - Service DNS
  - Profils itinérants
  - Sécurisation des communications LDAP (LDAPS)
  - Synchronisation NTP
- 3.3. Serveur Linux
  - Adressage et routage
  - SSH
  - Apache / HTTPS
  - Messagerie : Postfix / SMTPS / Dovecot
  - Supervision : Syslog et Zabbix
  - FTPS
  - SASL et certificats / autorité de certification
- 3.4. Switch Cisco (VLAN et trunk)

4. Tests d'intrusion — avant sécurisation
- Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto
- Attaque n°2 : Énumération LDAP
- Attaque n°3 : AS-REP Roasting
- Attaque n°4 : DHCP Rogue
- Attaque n°5 : MAC Flooding
- Attaque n°6 : ARP Spoofing
- Attaque n°7 : Scan Nmap des services Linux
- Attaque n°8 : Vérification des protections SSH
- Attaque n°9 : Vérification des protections FTP
- Attaque n°10 : Vérification de l'accès root SSH
- Attaque n°11 : Vérification du chiffrement des communications
- Attaque n°12 : Accès SYSVOL via SMB
- Attaque n°13 : SYN Flooding

5. Mesures de sécurisation appliquées
- Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto
- Attaque n°2 : Énumération LDAP
- Attaque n°3 : AS-REP Roasting
- Attaque n°4 : DHCP Rogue
- Attaque n°5 : MAC Flooding
- Attaque n°6 : ARP Spoofing
- Attaque n°7 : Scan Nmap des services Linux
- Attaque n°12 : Accès SYSVOL via SMB
- Attaque n°13 : SYN Flooding

6. Tests d'intrusion après sécurisation et diagnostics
- 6.1. Vérification après sécurisation, attaque par attaque

Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto
Attaque n°2 : Énumération LDAP
Attaque n°3 : AS-REP Roasting
Attaque n°4 : DHCP Rogue
Attaque n°5 : MAC Flooding
Attaque n°6 : ARP Spoofing
Attaque n°7 : Scan Nmap des services Linux
Attaque n°8 : Vérification des protections SSH
Attaque n°9 : Vérification des protections FTP
Attaque n°10 : Vérification de l'accès root SSH
Attaque n°11 : Vérification du chiffrement des communications
Attaque n°12 : Accès SYSVOL via SMB
Attaque n°13 : SYN Flooding
6.2. Diagnostics des services et des équipements
Serveur Windows — Active Directory
Serveur Windows — DNS
Serveur Windows — DHCP
Serveur Windows — LDAP / LDAPS
Serveur Windows — NTP
Postes clients
Serveur Linux — Services et réseau
Serveur Linux — Ports et chiffrement
Commutateur Cisco — Segmentation et protections
7. Bilan des vulnérabilités et contre-mesures
8. Conclusion

1. Présentation du projet et planning

Ce projet consiste à sécuriser un système d'information multi-site pour le compte de l'agence 4, en s'appuyant sur les recommandations de l'ANSSI. L'infrastructure comprend un pare-feu Stormshield SN320, un commutateur Cisco, un serveur Windows Server 2022 (Active Directory, DNS, DHCP) et un serveur Linux (Web, mail, FTP, supervision), répartis entre un réseau LAN et une DMZ.

Le diagramme de Gantt ci-dessous présente la planification des différentes séances du projet : installation et configuration de l'infrastructure, puis tests d'intrusion avant sécurisation, mise en place des contre-mesures, et enfin tests d'intrusion après sécurisation afin de valider l'efficacité des protections mises en place.

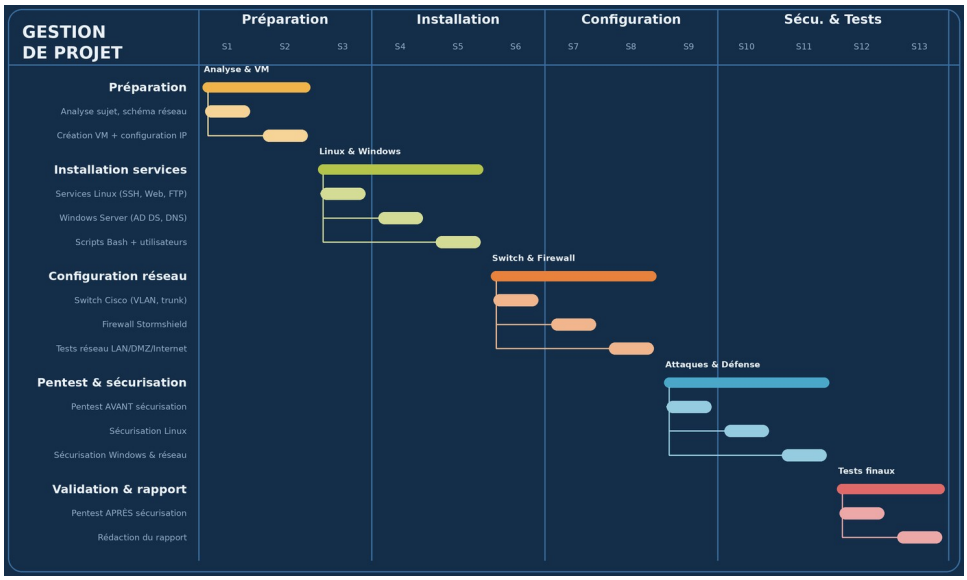


Diagramme de Gantt du projet — 13 séances réparties en 5 phases

La méthodologie suivie respecte donc une logique en quatre temps : installation et configuration de l'ensemble des équipements et services, tests d'intrusion à l'état initial (avant sécurisation), application des mesures de sécurisation recommandées, puis nouveaux tests d'intrusion (après sécurisation) afin de démontrer l'efficacité de chaque contre-mesure.

1.1. Matériel utilisé

- Switch Cisco C1000 — Ports 1 à 6 : VLAN 10 (LAN) ; Ports 7 à 12 : VLAN 20 (DMZ) ; Port 24 : Trunk vers le Firewall
- Firewall Stormshield — Port 1 (out) : connexion Internet via Backbone, IP 203.0.113.4/24, passerelle/DNS/NTP = 203.0.113.254
- Firewall Stormshield — Port 2 (in) : trunk VLAN vers le switch, IP 192.168.0.1/30 ; VLAN 10 = 192.168.4.254/24 ; VLAN 20 = 172.16.4.254/24
- PC Clients LAN
- PC Serveurs DMZ

2. Schéma réseau et plan d'adressage

L'architecture réseau repose sur trois zones distinctes : un réseau WAN donnant accès à Internet via le Backbone, un réseau LAN (VLAN 10) dédié aux postes utilisateurs, et une zone DMZ (VLAN 20) hébergeant les serveurs. Le commutateur Cisco C1000 assure la commutation et le relais des VLAN via un lien trunk vers le pare-feu Stormshield SN320, qui assure le routage entre zones, le filtrage et la publication des services vers Internet.

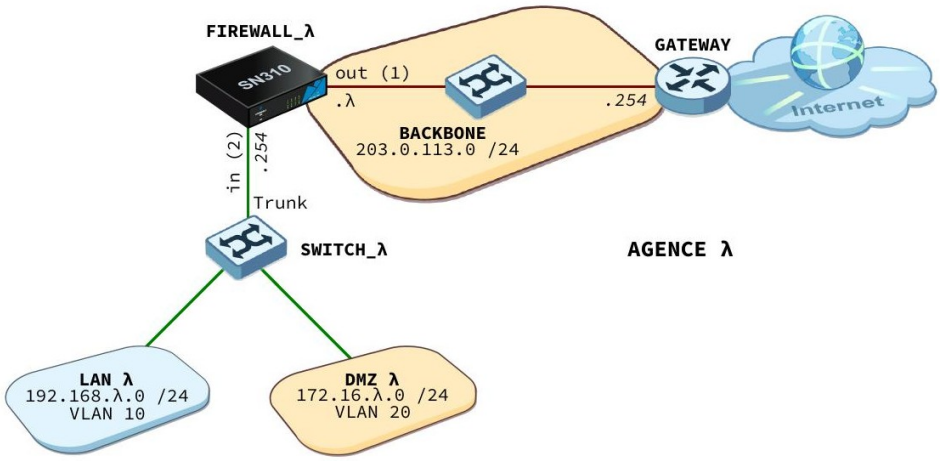


Schéma réseau de l'agence (sujet)

Plan d'adressage

Interface	Adresse IP	Rôle
WAN (out)	203.0.113.4/24	Accès Internet
LAN (VLAN 10)	192.168.4.254/24	Réseau utilisateurs
DMZ (VLAN 20)	172.16.4.254/24	Réseau serveurs

Plan d'adressage de l'infrastructure

Trois réseaux sont définis : le WAN (203.0.113.4/24) pour l'accès Internet, le LAN (VLAN 10, 192.168.4.0/24) pour les utilisateurs et la DMZ (VLAN 20, 172.16.4.0/24) pour les serveurs, chacun avec sa passerelle dédiée sur le pare-feu.

3. Installation et configuration de l'infrastructure

3.1. Pare-feu Stormshield SN320

Afin d'assurer la sécurité et la segmentation du système d'information, un pare-feu Stormshield SN320 a été déployé au cœur de l'infrastructure réseau. Cet équipement assure le routage entre les différents réseaux, le contrôle des flux ainsi que la publication des services vers Internet.

L'accès à l'interface d'administration a été réalisé via le port de configuration du pare-feu. Le plan d'adressage retenu repose sur trois réseaux distincts : un réseau WAN permettant l'accès à Internet, un réseau LAN destiné aux postes utilisateurs et une zone DMZ dédiée à l'hébergement des serveurs.



Page de présentation du projet

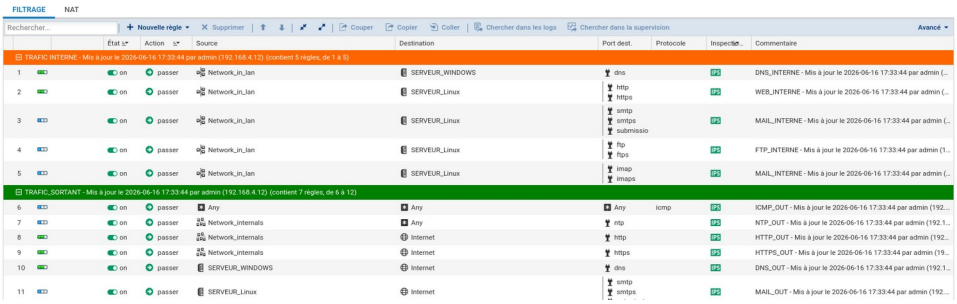
Bandeau de titre rappelant le sujet de la SAÉ 401 : sécuriser un système d'information.



Configuration des interfaces du pare-feu

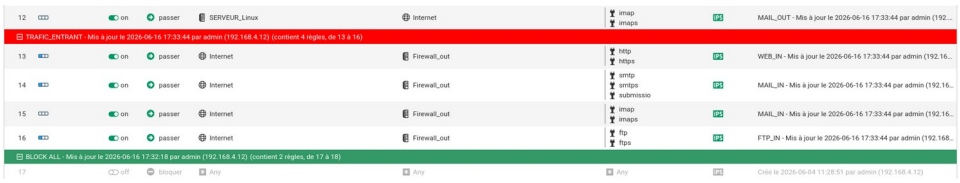
Les interfaces in_LAN (VLAN 10), in_DMZ (VLAN 20) et out sont créées avec leurs adresses respectives, assurant la séparation entre réseau utilisateurs, zone serveurs et accès Internet.

Une politique de filtrage temporaire « Block all » a été utilisée afin de simplifier les tests de connectivité entre les équipements durant la phase de déploiement.



Politique de filtrage du pare-feu

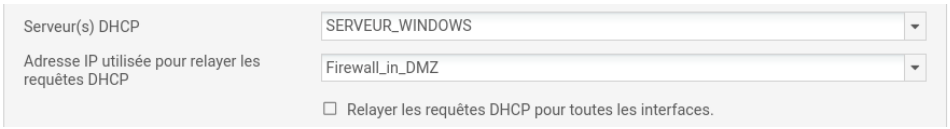
Les règles de filtrage autorisent les flux nécessaires (DNS, Web, mail) tout en bloquant le reste, conformément au principe du moindre privilège.



Politique de filtrage globale de test

Une règle « Block all » est utilisée pendant la phase de déploiement pour valider la connectivité avant de durcir le filtrage.

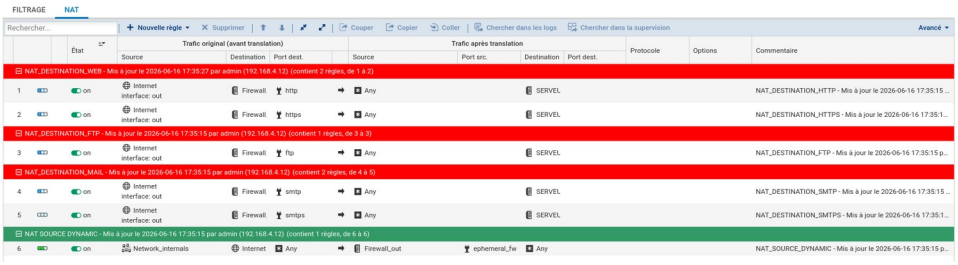
Le service DHCP étant hébergé sur le serveur Windows situé dans la DMZ, un relais DHCP a été configuré sur le pare-feu pour permettre aux postes clients du LAN d'obtenir automatiquement leur configuration IP.



Configuration du relais DHCP

Le pare-feu relaie les requêtes DHCP des clients LAN vers le serveur Windows situé en DMZ, tout en conservant la séparation des réseaux.

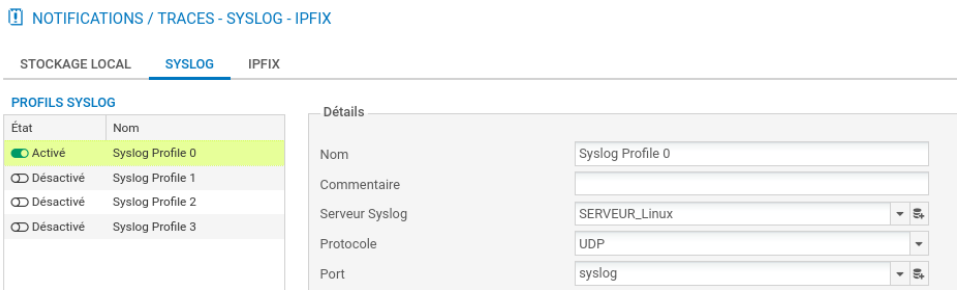
Des règles de traduction d'adresses (NAT) ont été mises en place afin de rendre accessibles depuis Internet les services hébergés dans la DMZ (Web, FTP, messagerie).



Règles de traduction d'adresses (NAT)

Les règles NAT publient vers Internet les services hébergés en DMZ (Web, FTP, mail) et masquent les adresses internes derrière l'adresse publique du pare-feu.

Afin de centraliser les journaux d'événements, le pare-feu a été configuré pour transmettre ses logs vers un serveur Syslog, et le protocole NTP a été configuré pour garantir une synchronisation cohérente de l'heure sur l'ensemble du réseau.



Configuration de l'envoi des logs (Syslog)

Le pare-feu est configuré pour transmettre ses journaux d'événements vers le serveur Syslog Linux (172.16.4.1) en UDP, afin de centraliser la supervision.

Configuration de la synchronisation NTP

Le pare-feu synchronise son horloge sur la passerelle, garantissant la cohérence temporelle des journaux et des services.

La configuration du pare-feu constitue la base de l'architecture de sécurité du projet : segmentation des réseaux, contrôle des communications inter-zones et publication sécurisée des services.

3.2. Serveur Windows Server 2022

Un serveur Windows Server 2022 a été déployé dans la zone DMZ afin d'héberger les principaux services d'infrastructure : Active Directory, DNS, DHCP, profils itinérants et sécurisation des communications LDAP.

- Active Directory Domain Services (AD DS) : création du domaine agence4.fr et gestion centralisée des utilisateurs et des ressources
- DNS : résolution des noms au sein du domaine grâce à une zone directe et une zone inverse
- DHCP : attribution automatique des adresses IP et des paramètres réseau aux postes clients
- NTP : synchronisation de l'heure entre les différents équipements de l'infrastructure
- Profils itinérants : centralisation des données utilisateurs sur le serveur
- LDAPS : sécurisation des communications LDAP grâce au chiffrement TLS

Configuration réseau

Le serveur a été installé sur une VM VirtualBox en mode « accès par pont » et configuré avec l'adresse fixe 172.16.4.3 dans la DMZ, avec le pare-feu Stormshield comme passerelle par défaut.

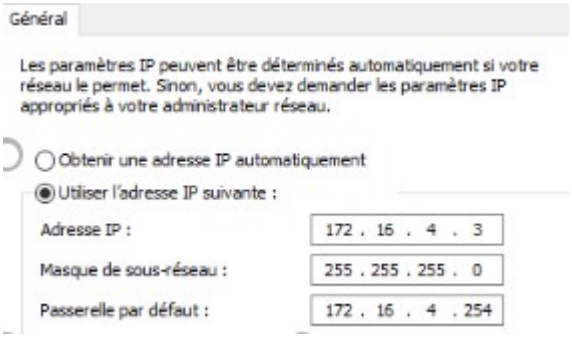


Adresse de l'interface WAN

L'interface « out » du pare-feu porte l'adresse publique 203.0.113.4/24 qui assure la liaison vers le Backbone et Internet.

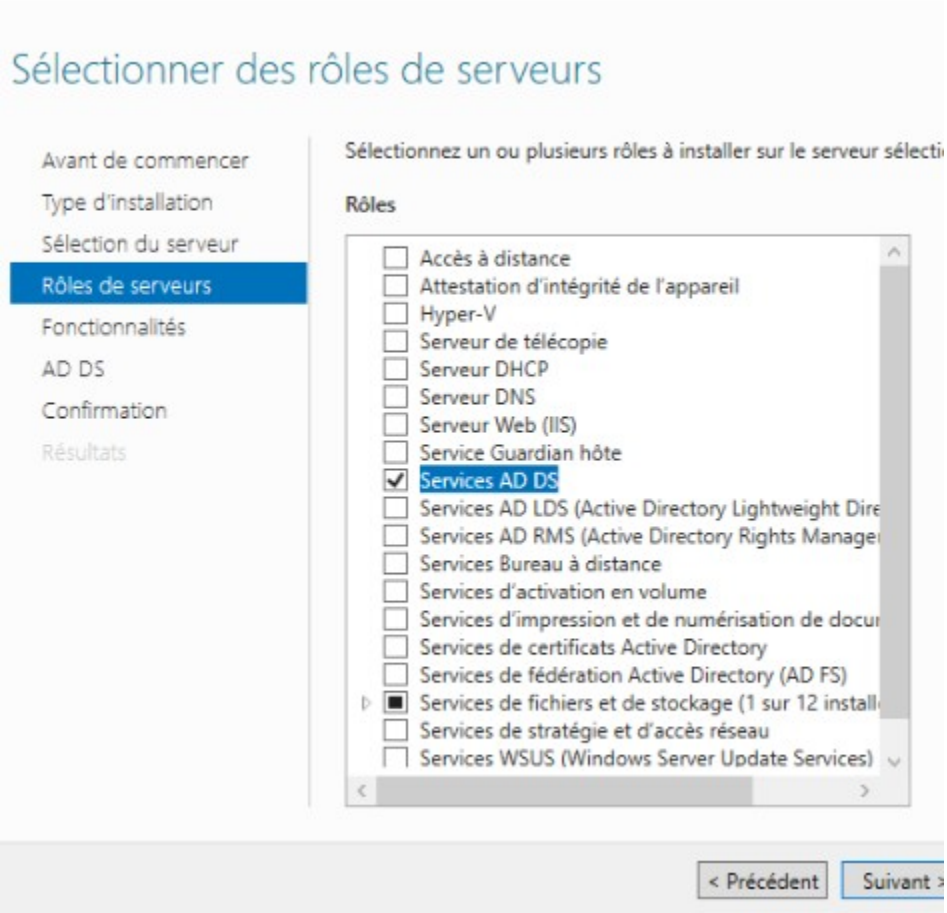
Active Directory Domain Services

Le rôle AD DS a été installé puis le serveur a été promu contrôleur de domaine principal en créant la forêt agence4.fr. Plusieurs unités d'organisation (OU) ont été créées pour structurer les ressources, ainsi que des groupes de sécurité et comptes utilisateurs.



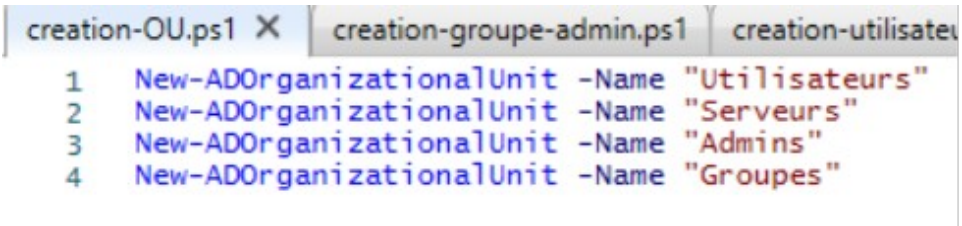
Adressage IP fixe du serveur Windows

Le serveur reçoit l'adresse statique 172.16.4.3 avec le pare-feu (172.16.4.254) comme passerelle, indispensable pour des services d'infrastructure toujours joignables.



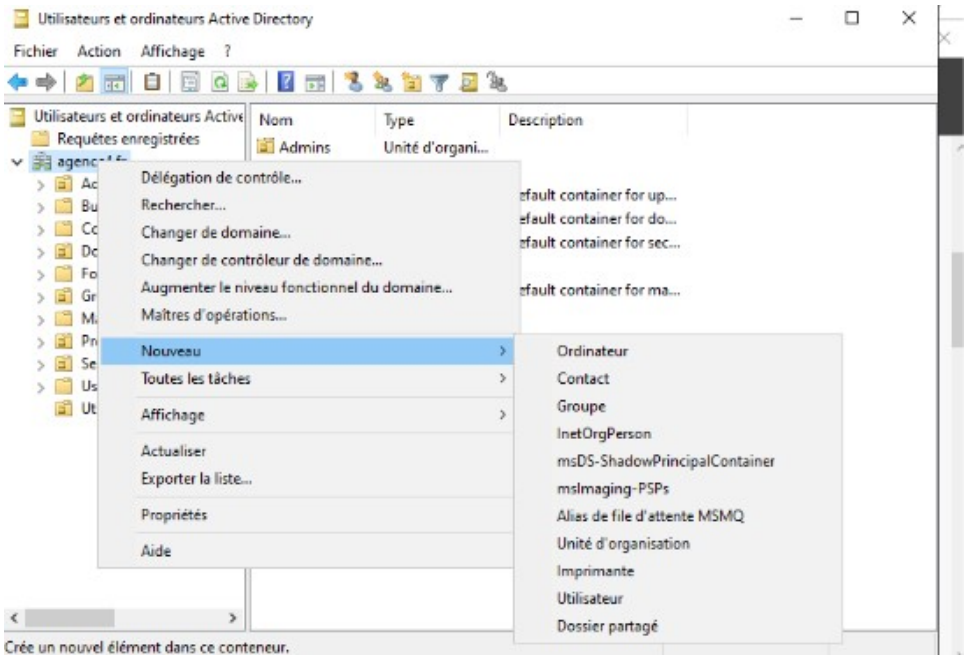
Installation du rôle Active Directory (AD DS)

Le rôle Active Directory Domain Services est sélectionné dans l'assistant d'ajout de rôles afin de promouvoir le serveur en contrôleur de domaine.



Création des unités d'organisation par script

Un script PowerShell crée les OU Utilisateurs, Serveurs, Admins et Groupes, structurant proprement l'annuaire du domaine agence4.fr.

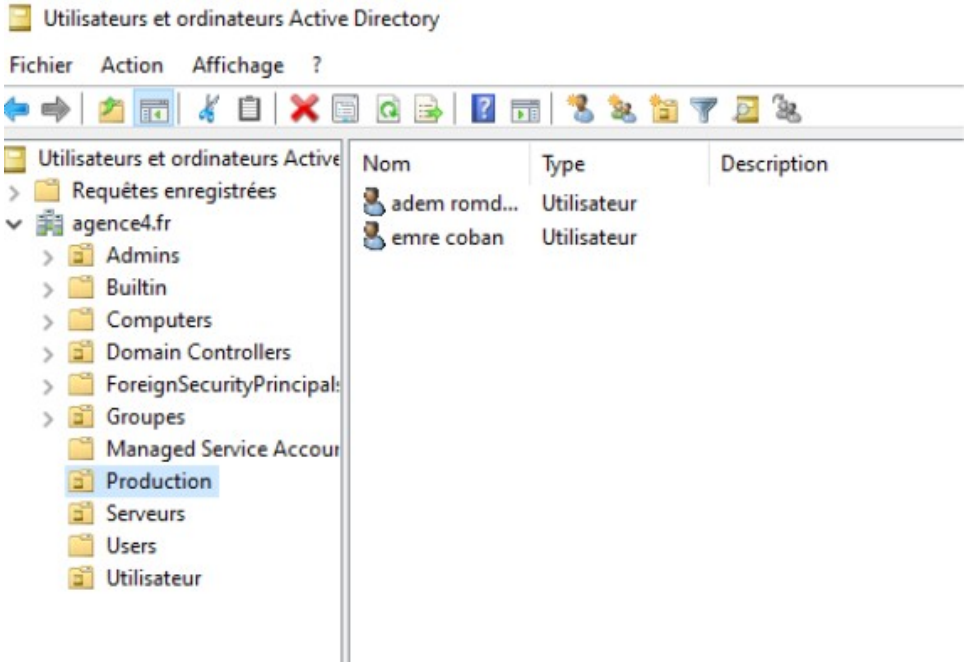


Console de gestion Active Directory

La console « Utilisateurs et ordinateurs Active Directory » permet de créer et d'organiser les objets du domaine (OU, groupes, comptes).

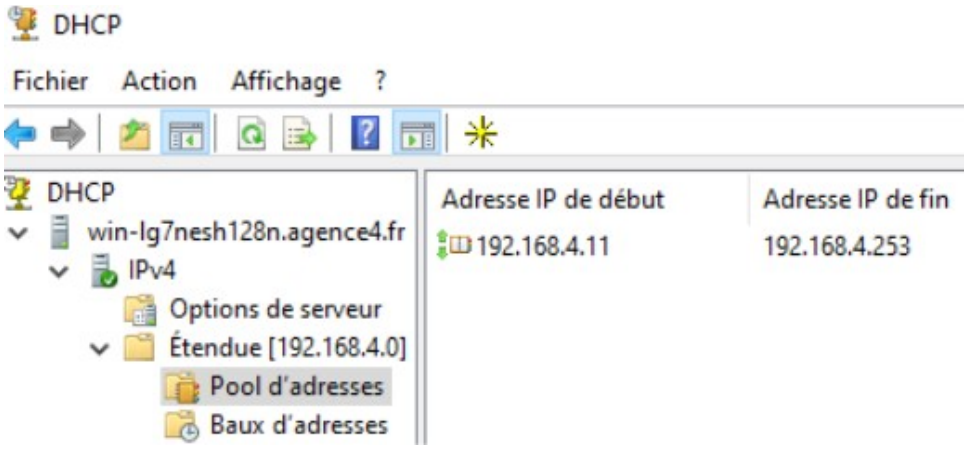
Service DHCP

Une étendue DHCP a été créée pour le réseau 192.168.4.0/24, avec un pool d'adresses de 192.168.4.11 à 192.168.4.253, distribuant automatiquement la passerelle (192.168.4.254) et le serveur DNS (172.16.4.3).



Comptes utilisateurs du domaine

Les comptes utilisateurs (adem, emre…) sont créés dans l'OU de production, reproduisant une structure d'entreprise.

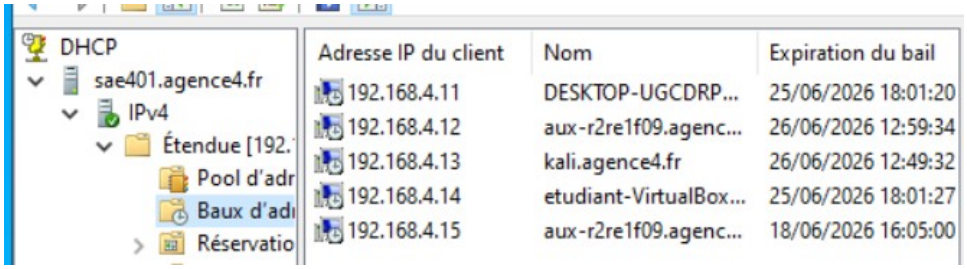


Étendue DHCP du réseau LAN

Une étendue DHCP couvre le réseau 192.168.4.0/24 avec un pool d'adresses de 192.168.4.11 à 192.168.4.253 distribué aux postes clients.

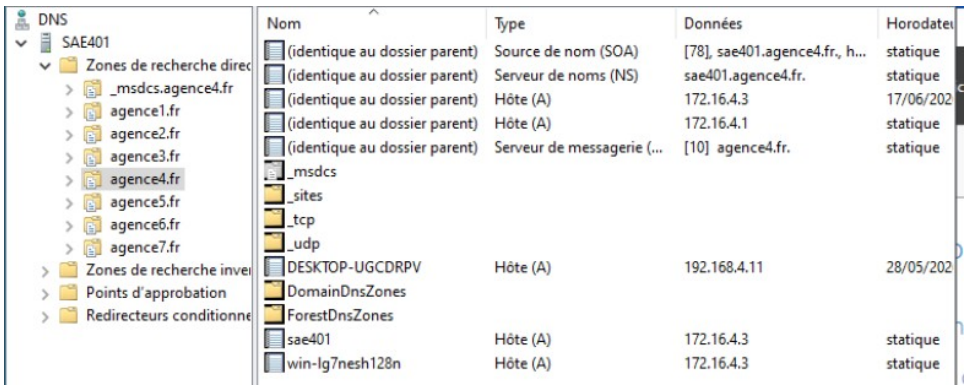
Service DNS

Une zone de recherche directe et une zone de recherche inverse ont été créées pour assurer la résolution des noms au sein du domaine agence4.fr.



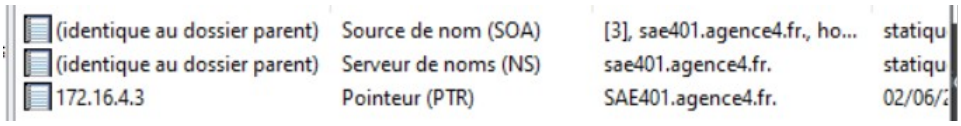
Baux DHCP attribués aux clients

Les baux montrent que les postes du LAN obtiennent automatiquement une adresse IP et le nom associé, confirmant le bon fonctionnement du service DHCP.



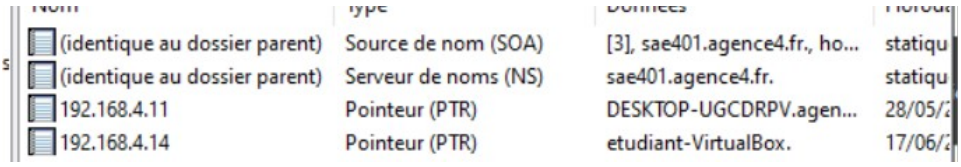
Zone DNS de recherche directe

La zone agence4.fr contient les enregistrements (A, SRV, etc.) permettant la résolution des noms vers les adresses IP au sein du domaine.



Zone DNS de recherche inverse (serveur)

La résolution inverse associe l'adresse 172.16.4.3 au nom du serveur via un enregistrement PTR.

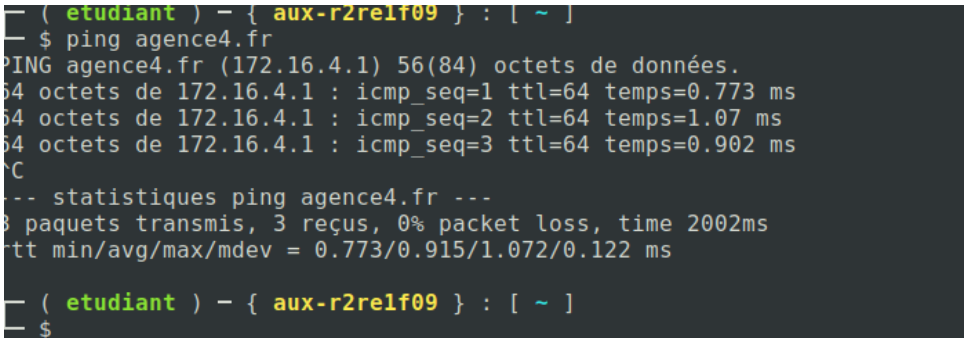


Zone DNS de recherche inverse (clients)

Les enregistrements PTR des postes clients confirment la résolution inverse complète des adresses du réseau.

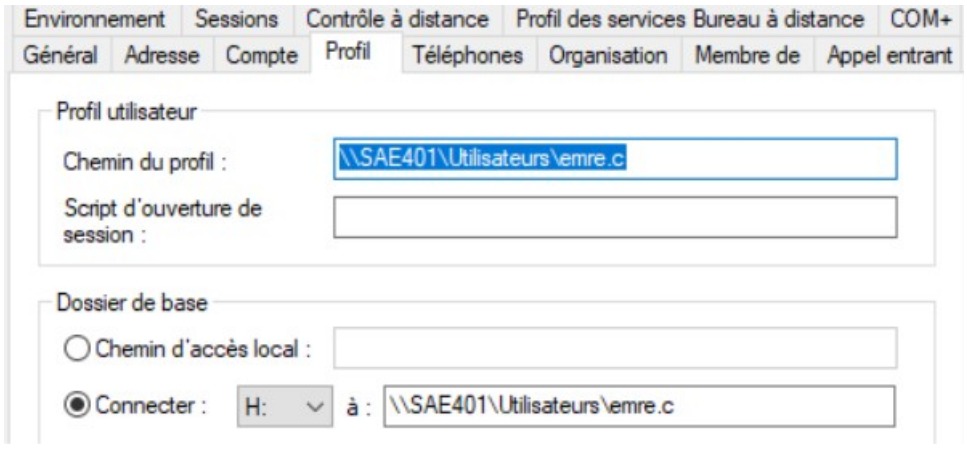
Profils itinérants

Un partage réseau dédié a été créé et renseigné dans les propriétés des comptes utilisateurs, permettant aux utilisateurs de retrouver leur environnement de travail quel que soit le poste utilisé.



Test de résolution et de connectivité DNS

Le ping vers agence4.fr résout correctement le nom et obtient une réponse, validant à la fois le DNS et la connectivité réseau.

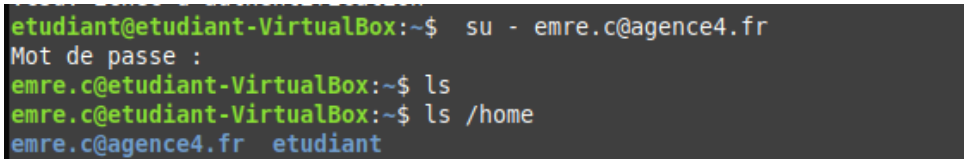


Configuration d'un profil itinérant

Le chemin du profil utilisateur pointe vers un partage réseau (\\SAE401\Utilisateurs), centralisant les données de session sur le serveur.

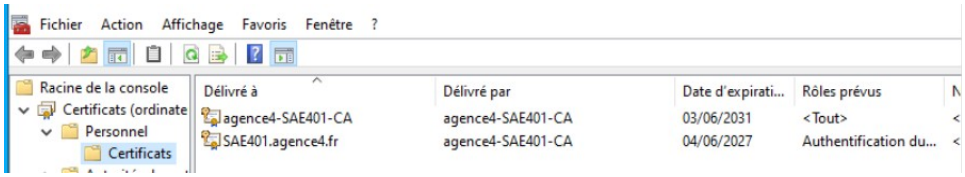
Sécurisation des communications LDAP (LDAPS)

Une autorité de certification a été installée puis un certificat a été généré et déployé sur le contrôleur de domaine, permettant de sécuriser les communications LDAP via TLS sur le port 636 (vérifié avec Ldp.exe).



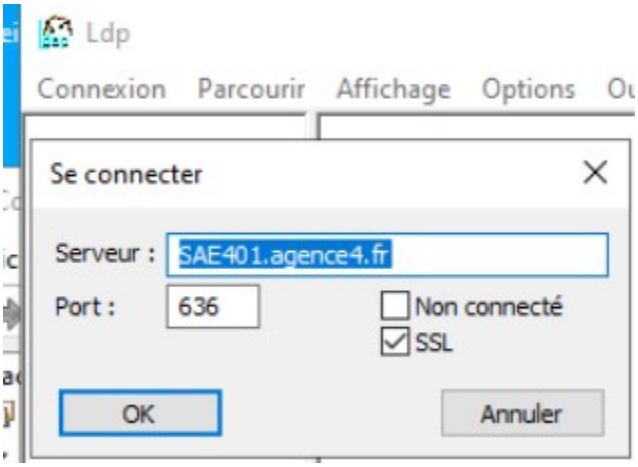
Validation du profil itinérant côté client

L'ouverture de session avec un compte du domaine charge bien le profil depuis le serveur, confirmant le fonctionnement des profils itinérants.



Autorité de certification du domaine

Une autorité de certification (agence4-SAE401-CA) est installée pour délivrer les certificats utilisés notamment par LDAPS.

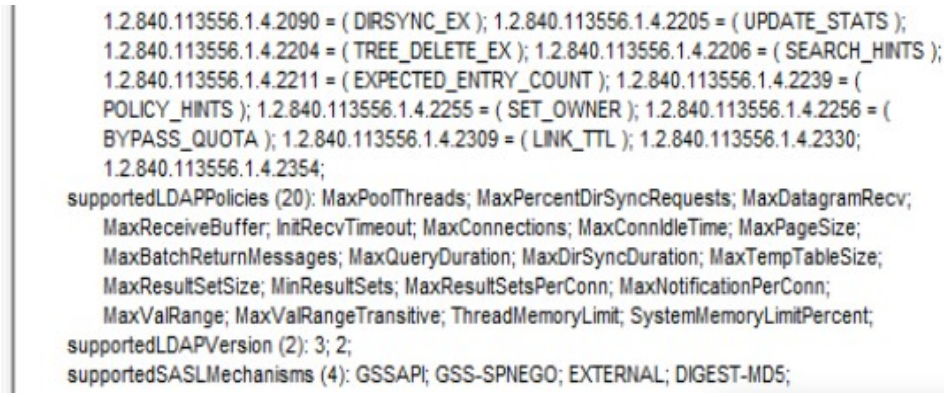


Connexion LDAPS de test (Ldp.exe)

L'outil Ldp.exe établit une connexion sécurisée vers le contrôleur de domaine sur le port 636 avec l'option SSL activée.

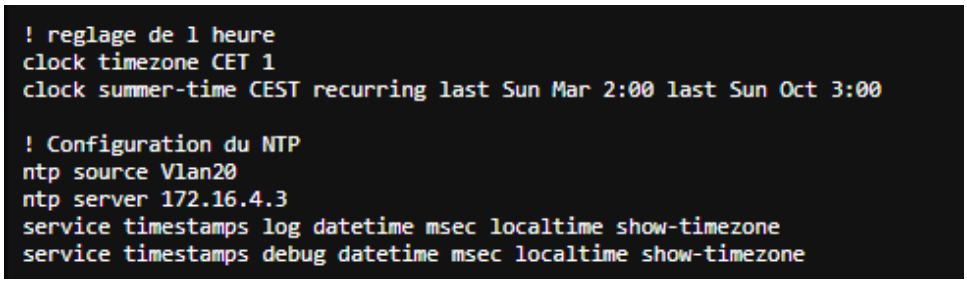
Synchronisation NTP

Le protocole NTP a été configuré sur le switch, le pare-feu et le serveur Windows afin de garantir une synchronisation cohérente de l'heure sur l'ensemble de l'infrastructure (important pour Kerberos/AD et les journaux d'événements).



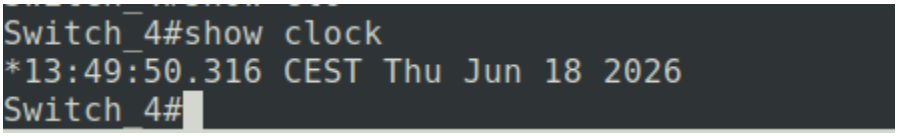
Résultat de la connexion LDAPS

La réponse du serveur (politiques et mécanismes SASL supportés) confirme que la connexion LDAP chiffrée via TLS fonctionne.



Configuration NTP du commutateur

Le commutateur Cisco est configuré pour se synchroniser sur le serveur NTP 172.16.4.3 avec le fuseau horaire CET.



Vérification de l'heure du commutateur

La commande show clock confirme que le commutateur est correctement synchronisé à l'heure du réseau.



Règle de filtrage NTP du pare-feu

Une règle autorise le trafic NTP depuis les réseaux internes, garantissant la synchronisation horaire des équipements.



Forçage de la synchronisation NTP (Windows)

Un script w32tm force la synchronisation de l'horloge du serveur Windows, essentielle au bon fonctionnement de Kerberos.

3.3. Serveur Linux

Un serveur Linux a été déployé dans la DMZ afin d'héberger les services Web (Apache/HTTPS), de messagerie (Postfix/Dovecot/SMTPS), de transfert de fichiers (FTPS), de supervision (Syslog/Zabbix) ainsi que l'accès distant sécurisé (SSH).

Adressage et routage

Une adresse IP statique a été configurée dans la DMZ, avec une route par défaut pointant vers le pare-feu Stormshield. Le serveur Windows a été ajouté comme second serveur DNS.

```
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP gr
oup default qlen 1000
    link/ether 08:00:27:55:3b:16 brd ff:ff:ff:ff:ff:ff
    altname enx080027553b16
    inet 172.16.4.1/24 brd 172.16.4.255 scope global enp0s3
       valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe55:3b16/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
jojo@debian:~$
```

Adressage du serveur Linux

La commande ip a montre l'interface configurée avec l'adresse statique 172.16.4.1 en DMZ.

```
jojo@debian:~$ ip r
default via 172.16.4.254 dev enp0s3 onlink
172.16.4.0/24 dev enp0s3 proto kernel scope link src 172.16.4.1
jojo@debian:~$
```

Route par défaut du serveur Linux

La table de routage indique la passerelle par défaut 172.16.4.254, soit le pare-feu Stormshield.

```
jojo@debian:~$ cat -n /etc/network/interfaces
     1  # This file describes the network interfaces available on your system
     2  # and how to activate them. For more information, see interfaces(5).
     3
     4  source /etc/network/interfaces.d/*
     5
     6  # The loopback network interface
     7  auto lo
     8  iface lo inet loopback
     9
    10  auto enp0s3
    11  iface enp0s3 inet static
    12      address 172.16.4.1
    13      netmask 255.255.255.0
    14      gateway 172.16.4.254
    15      dns-nameservers 172.16.4.3
jojo@debian:~$
```

Configuration réseau persistante (Linux)

Le fichier /etc/network/interfaces fixe l'adresse 172.16.4.1, le masque, la passerelle et le serveur DNS du serveur Linux.

```
jojo@debian:~$ cat -n /etc/resolv.conf
     1  # Generated by NetworkManager
     2  nameserver 172.16.4.3
jojo@debian:~$
```

Configuration DNS du serveur Linux

Le fichier /etc/resolv.conf pointe vers le serveur DNS interne 172.16.4.3, assurant la résolution des noms du domaine.

SSH

Le service SSH a été configuré pour l'administration distante, avec mise en place de l'authentification par clé publique (afin de pouvoir se connecter sans mot de passe via un alias 'ssh server'), ainsi qu'une connexion test depuis le switch Cisco.

```
jojo@debian:~$ cat -n /etc/ssh/sshd_config
```

Configuration SSH — port d'écoute

Le service SSH est configuré pour écouter sur le port 2222 plutôt que le port 22 par défaut, réduisant les scans automatisés.

```
Port 2222
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::
```

Configuration SSH — interfaces d'écoute

Les directives d'écoute du démon SSH sont définies dans sshd_config.

```
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Durcissement SSH — interdiction du root

La directive PermitRootLogin no interdit toute connexion directe au compte administrateur root.

```
# To disable tunneled clear text passwords, change to "no" here!
PasswordAuthentication no
```

Durcissement SSH — clé obligatoire

La directive PasswordAuthentication no désactive l'authentification par mot de passe au profit de l'authentification par clé.

```
jojo@debian:~$ cat ~/.ssh/authorized_keys
```

Clés publiques autorisées (SSH)

Le fichier authorized_keys contient les clés publiques des clients autorisés à se connecter sans mot de passe.

```
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOHDOE7CAZozpfBkXClS5Hr7pigjZFpoHz3YorNyu2yD client-jojo
jojo@debian:~$
```

Clé publique du client

La clé publique ssh-ed25519 du client est enregistrée sur le serveur pour l'authentification par clé.

```
┌─( etudiant )─{ aux-r2re1f09 }─:─[ ~ ]
└─$ ssh -p 2222 jojo@172.16.4.1
jojo@172.16.4.1: Permission denied (publickey).
```

Tentative SSH sans clé

Depuis un client ne disposant pas de la clé, la connexion est refusée (Permission denied / publickey), prouvant que seul l'accès par clé est accepté.



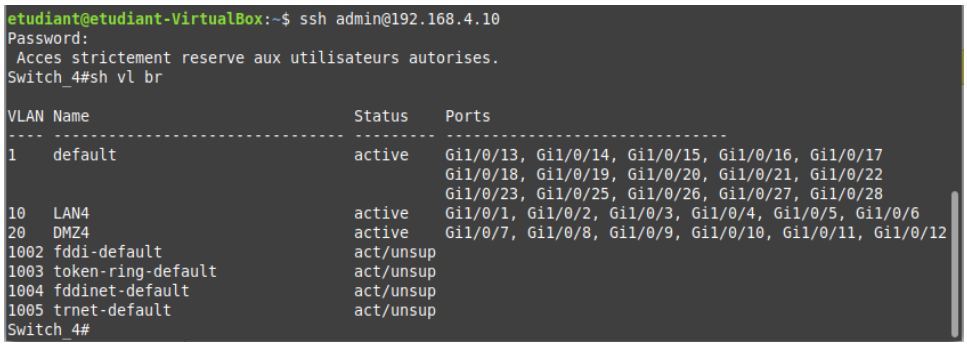
Connexion SSH avec clé

Depuis le client disposant de la clé, la connexion réussit et ouvre une session sur le serveur Debian.



Alias de connexion SSH

Le fichier ~/.ssh/config définit un alias « server » (HostName, Port 2222, clé), permettant de se connecter simplement avec « ssh server ».

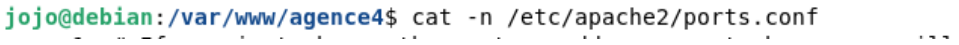


Connexion SSH au commutateur

Une connexion SSH vers le commutateur (192.168.4.10) permet de l'administrer à distance de façon sécurisée.

Apache / HTTPS

Le serveur Web a été configuré pour n'écouter que sur le port 443 (HTTPS), avec une redirection automatique des requêtes HTTP vers le nom de domaine https://agence4.fr, conformément au certificat SSL du site, dont le contenu est servi depuis /var/www/agence4.



Configuration Apache — ports d'écoute

Le fichier ports.conf n'active l'écoute que sur le port 443 (HTTPS) au sein du module SSL.

```
#Listen 80

<IfModule ssl_module>
        Listen 443
</IfModule>

<IfModule mod_gnutls.c>
        Listen 443
</IfModule>
```

Désactivation du HTTP en clair

Le port 80 (HTTP) est commenté au profit du port 443 (HTTPS) uniquement.

```
jojo@debian:/var/www/agence4$ cat -n /etc/apache2/sites-available/default-ssl.conf
```

Configuration du VirtualHost SSL

Le fichier default-ssl.conf définit la configuration du site sécurisé en HTTPS.

```
<VirtualHost *:443>
        ServerName agence4.fr
        ServerAdmin webmaster@localhost
        RewriteEngine On
        RewriteCond %{HTTP_HOST} ^172\.16\.4\.1$
        RewriteRule ^(.*)$ https://agence4.fr$1 [R=301,L]

        DocumentRoot /var/www/agence4
```

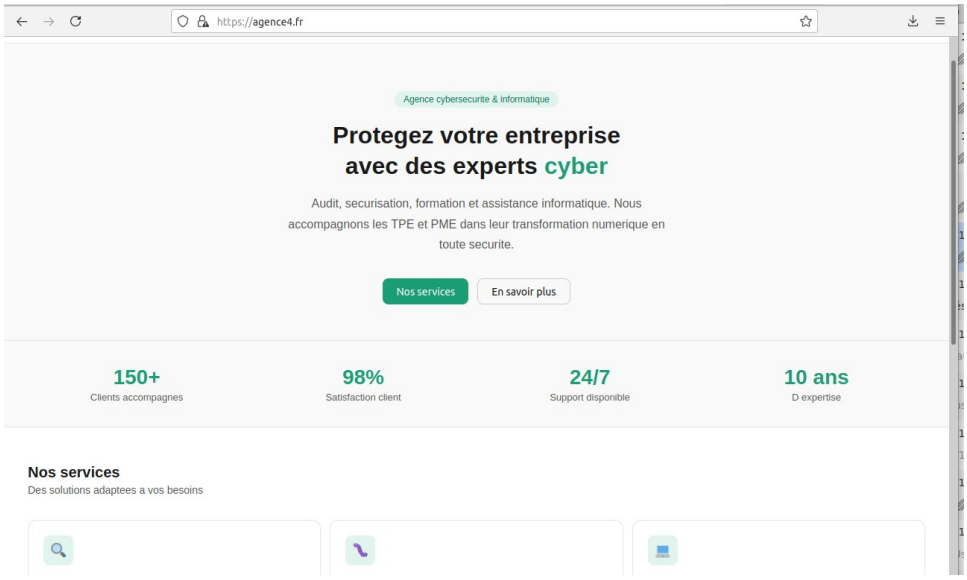
Redirection HTTP vers HTTPS

La règle de réécriture redirige automatiquement les requêtes vers https://agence4.fr, forçant l'usage du HTTPS et du nom de domaine.

```
jojo@debian:/var/www/agence4$ ls
index.html
jojo@debian:/var/www/agence4$
```

Contenu du site Web

Le répertoire /var/www/agence4 contient le site (index.html) servi par Apache.



Site Web accessible en HTTPS

Le navigateur affiche le site « Agence cybersécurité » via https://agence4.fr, confirmant le bon fonctionnement du serveur Web sécurisé.

```
emre.c@etudiant-VirtualBox:~$ curl -k https://172.16.4.1
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="https://agence4.fr/">here</a>.</p>
<hr>
<address>Apache/2.4.67 (Debian) Server at 172.16.4.1 Port 443</address>
</body></html>
emre.c@etudiant-VirtualBox:~$
```

Vérification de la redirection (curl)

La requête curl renvoie un code 301 redirigeant vers https://agence4.fr, prouvant la redirection automatique HTTP → HTTPS.

```
jojo@debian:/var/www/agence4$ sudo systemctl status apache2
[sudo] Mot de passe de jojo :
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-06-18 12:21:54 CEST; 3h 58min ago
 Invocation: fb1053e4497a49fa8d78bb599074779e
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 861 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
```

État du service Apache

Le service apache2 est actif (running), confirmant que le serveur Web fonctionne.

```
jojo@debian:/var/www/agence4$ sudo apachectl configtest
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.
0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
jojo@debian:/var/www/agence4$
```

Vérification de la configuration Apache

La commande apachectl configtest renvoie « Syntax OK », validant la configuration du serveur Web.

Messagerie : Postfix / SMTPS / Dovecot

La messagerie sécurisée a été mise en place avec Postfix (SMTPS) et Dovecot, et testée par l'envoi d'un message vers l'agence 7 ainsi que par la réception de sa réponse.

```
jojo@debian:/var/www/agence4$ cat -n /etc/postfix/main.cf
```

Configuration Postfix (main.cf)

Le fichier principal de Postfix définit les paramètres du serveur de messagerie.

```
# SMTP server RSA key and certificate in PEM format
smtpd_tls_key_file = /etc/ssl/private/postfix.key
smtpd_tls_cert_file = /etc/ssl/certs/postfix.crt
# SMTP Server security level: none|may|encrypt
smtpd_tls_security_level = may

# List of CAs for SMTP Client to trust
# Prefer this over _CApath when smtp is running chrooted
smtpd_tls_CAfile = /etc/ssl/CA/ca.crt
```

Configuration TLS de Postfix

Les directives smtpd_tls_* activent le chiffrement TLS pour les échanges de messagerie (SMTPS).

```
smtpd_sasl_auth_enable = yes
smtpd_sasl_security_options = noanonymous
broken_sasl_auth_clients = yes
```

Authentification SASL de Postfix

L'option smtpd_sasl_auth_enable=yes impose l'authentification SASL et interdit les connexions anonymes.

```
mydestination = $myhostname, server.dmz4, debian, agence4.fr, localhost.localdomain, localhost
```

Domaines gérés par Postfix

Le paramètre mydestination définit les domaines de messagerie pris en charge par le serveur.

```
jojo@debian:/var/www/agence4$ cat -n /etc/postfix/master.cf
```

Configuration des services Postfix (master.cf)

Le fichier master.cf déclare les services Postfix, dont le service SMTPS chiffré.

```
12  smtp      inet  n       -       y       -       -       smtpd
13  smtps     inet  n       -       y       -       -       smtpd
14    -o syslog_name=postfix/smtps
15    -o smtpd_tls_wrappermode=yes
16    -o smtpd_tls_security_level=encrypt
17    -o smtpd_tls_cert_file=/etc/ssl/certs/postfix.crt
18    -o smtpd_tls_key_file=/etc/ssl/private/postfix.key
```

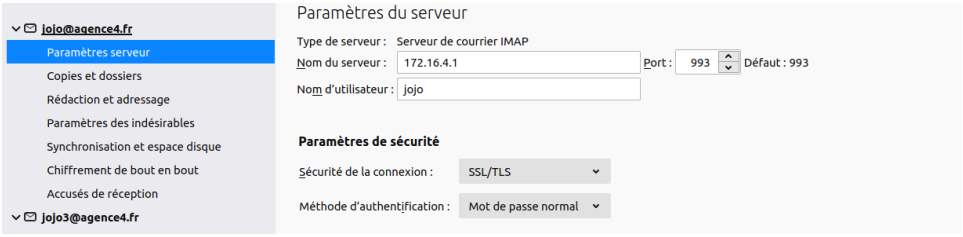
Service SMTPS dans master.cf

Le service smtps est activé avec le mode wrapper TLS et les certificats associés, sécurisant l'envoi de courrier.

```
jojo@debian:/var/www/agence4$ sudo systemctl status postfix
● postfix.service - Postfix Mail Transport Agent (main/default instance)
     Loaded: loaded (/usr/lib/systemd/system/postfix.service; enabled; preset: enabled)
     Active: active (running) since Thu 2026-06-18 12:21:54 CEST; 4h 7min ago
```

État du service Postfix

Le service postfix est actif (running), confirmant le fonctionnement du serveur de messagerie.



Configuration du client mail (IMAP/SSL)

Le client Thunderbird est paramétré pour se connecter au serveur 172.16.4.1 sur le port 993 avec SSL/TLS.



Envoi d'un courriel de test

Un message est envoyé depuis l'agence 4 vers l'agence 7, validant l'émission de courrier.



Réception de la réponse

La réponse de l'agence 7 est bien reçue, confirmant le bon fonctionnement bidirectionnel de la messagerie.

```
jojo@debian:~$ sudo systemctl status dovecot
● dovecot.service - Dovecot IMAP/POP3 email server
     Loaded: loaded (/usr/lib/systemd/system/dovecot.service; enable>
     Active: active (running) since Fri 2026-06-19 15:21:49 CEST; 33>
 Invocation: b917aad3d7b34a8b9aace81247be76c1
       Docs: man:dovecot(1)
             https://doc.dovecot.org/
   Main PID: 913 (dovecot)
     Status: "v2.4.1-4 (7d8c0e5759) running"
```

État du service Dovecot

Le service dovecot (IMAP/POP3) est actif (running) en version récente, assurant la réception des courriels.

```
jojo@debian:~$ grep -v '^#' /etc/dovecot/conf.d/10-ssl.conf | grep -v
 '^$'
ssl = yes
ssl_server_cert_file = /etc/ssl/certs/dovecot.crt
ssl_server_key_file = /etc/ssl/private/dovecot.key
ssl_server_ca_file = /etc/ssl/CA/ca.crt
ssl_min_protocol = TLSv1.2
jojo@debian:~$
```

Chiffrement TLS de Dovecot

La configuration impose ssl=yes avec certificat, clé et TLS 1.2 minimum, garantissant des connexions IMAP/POP3 chiffrées.

Supervision : Syslog et Zabbix

Les journaux du pare-feu et des équipements sont centralisés via Syslog, organisés par répertoire d'adresse IP, et un serveur Zabbix a été mis en place pour la supervision et la base de données associée.

```
jojo@debian:/etc/rsyslog.d$ cat 60-remote-logs.conf
$template RemoteLogs,"/var/log/remote/%fromhost-ip%/%PROGRAMNAME%.log"
if $fromhost-ip == '192.168.4.10' or $fromhost-ip == '172.16.4.10' then /var/log/remote/switch.log
& stop
*.* ?RemoteLogs
& stop
jojo@debian:/etc/rsyslog.d$
```

Configuration de la centralisation des logs

Le fichier rsyslog redirige les journaux distants dans des fichiers séparés par adresse IP source.

```
jojo@debian:/var/log$ sudo cat syslog
```

Consultation du journal système

Le fichier syslog regroupe les événements reçus des équipements du réseau.

```
54 origdstport=53 ipv=4 sent=61 rcvd=86 duration=0.01 action=pass logtype="connection"
2026-06-17T14:58:14+02:00 FIREWALL_4 asqd id=firewall time="2026-06-17 14:58:14" fw="FIREWALL_4" tz=+020
0 startime="2026-06-17 14:56:12" pri=5 confid=01 slotlevel=2 ruleid=1 rulename="19ed1113143_6" srcif="vl
an0" srcifname="in_lan" ipproto=udp dstif="vlan1" dstifname="in_DMZ" proto=dns_udp src=192.168.4.12 srcp
ort=58523 srcportname=ephemeral_fw_udp srcmac=50:3e:aa:14:cd:7f dst=172.16.4.3 dstport=53 dstportname=dn
s_udp dstname=sae401.agence4.fr modsrc=192.168.4.12 modsrcport=58523 origdst=172.16.4.3 origdstport=53 i
pv=4 sent=52 rcvd=188 duration=0.01 action=pass logtype="connection"
2026-06-17T14:58:18+02:00 FIREWALL_4 asqd id=firewall time="2026-06-17 14:58:18" fw="FIREWALL_4" tz=+020
0 startime="2026-06-17 14:56:25" pri=5 confid=01 slotlevel=2 ruleid=9 rulename="19ed1113147_e" srcif="vl
an0" srcifname="in_lan" ipproto=tcp dstif="Ethernet0" dstifname="out" proto=ssl version=TLSv1.3 src=192.
168.4.12 srcport=37086 srcportname=ephemeral_fw_tcp srcmac=50:3e:aa:14:cd:7f dst=52.108.8.12 dstport=443
 dstportname=https dstname=frc-word-edit.officeapps.live.com dstcontinent="na" dstcountry="us" dstiprep=
"azuredevops,microsoftcopilot,microsoftpublicips,o365common" modsrc=203.0.113.4 modsrcport=37086 origdst
=52.108.8.12 origdstport=443 ipv=4 sent=33139 rcvd=23200 duration=107.28 action=pass logtype="connection
"
jojo@debian:/var/log$ ^C
jojo@debian:/var/log$ sudo cat syslog
```

Logs détaillés du pare-feu

Les journaux du pare-feu transmis par Syslog sont consultables sur le serveur Linux.

```
jojo@debian:/var/log/remote$ ls
127.0.0.1  172.16.4.10  172.16.4.254  192.168.4.10  switch.log
```

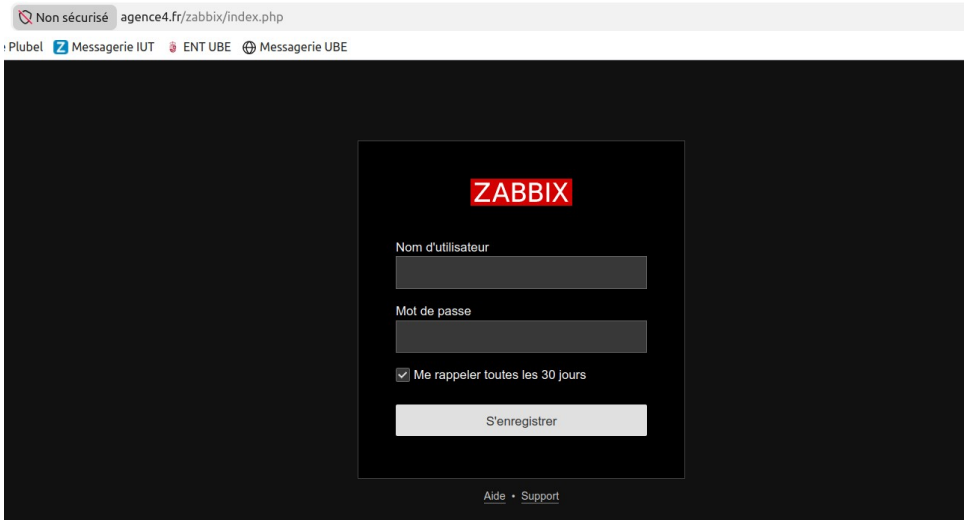
Organisation des logs par équipement

Le répertoire /var/log/remote classe les journaux par adresse IP source (pare-feu, switch, clients), facilitant l'analyse.

```
2026-06-18T15:33:00.927681+02:00 172.16.4.10 346: *Jun 18 13:36:32.196: %PM-4-ERR_DISABLE: psecure-viola
tion error detected on Gi1/0/1, putting Gi1/0/1 in err-disable state
2026-06-18T15:33:01.923686+02:00 172.16.4.10 347: *Jun 18 13:36:32.255: %PORT_SECURITY-2-PSECURE_VIOLATI
ON: Security violation occurred, caused by MAC address 00f5.7f1e.3dbd on port GigabitEthernet1/0/1.
2026-06-18T15:33:02.923445+02:00 172.16.4.10 348: *Jun 18 13:36:33.254: %LINEPROTO-5-UPDOWN: Line protoc
ol on Interface GigabitEthernet1/0/1, changed state to down
2026-06-18T15:33:03.924359+02:00 172.16.4.10 349: *Jun 18 13:36:34.255: %LINK-3-UPDOWN: Interface Gigabi
tEthernet1/0/1, changed state to down
2026-06-18T15:41:09.077555+02:00 172.16.4.10 350: *Jun 18 13:44:39.385: %LINK-5-CHANGED: Interface Gigab
itEthernet1/0/1, changed state to administratively down
2026-06-18T15:41:11.828355+02:00 172.16.4.10 351: *Jun 18 13:44:42.333: %SYS-5-CONFIG_I: Configured from
 console by admin on console
2026-06-18T15:41:12.843437+02:00 172.16.4.10 352: *Jun 18 13:44:43.136: %LINK-3-UPDOWN: Interface Gigabi
tEthernet1/0/1, changed state to down
2026-06-18T15:41:15.778755+02:00 172.16.4.10 353: *Jun 18 13:44:46.086: %LINK-3-UPDOWN: Interface Gigabi
tEthernet1/0/1, changed state to up
2026-06-18T15:41:15.778939+02:00 172.16.4.10 354: *Jun 18 13:44:47.086: %LINEPROTO-5-UPDOWN: Line protoc
ol on Interface GigabitEthernet1/0/1, changed state to up
2026-06-18T15:41:48.554886+02:00 172.16.4.10 355: *Jun 18 13:45:18.861: %SW_DAI-4-ACL_DENY: 3 Invalid AR
Ps (Req) on Gi1/0/1, vlan 10.([503e.aa14.cd7f/0.0.0.0/0000.0000.0000/192.168.4.12/15:45:17 CEST Thu Jun
18 2026])
jojo@debian:/var/log/remote$
```

Logs du commutateur reçus

Le fichier switch.log contient les journaux du commutateur transmis au serveur central.



Interface de supervision Zabbix

La page de connexion Zabbix confirme la mise en place de l'outil de supervision.

```
MariaDB [zabbix]> SELECT host, status FROM hosts WHERE host LIKE '%SA
E%' OR host LIKE '%Debian%';
+------------+--------+
| host       | status |
+------------+--------+
| Debian-SAE |      0 |
+------------+--------+
1 row in set (0,000 sec)

MariaDB [zabbix]>
```

Base de données Zabbix

La requête SQL sur la base zabbix montre les hôtes supervisés, confirmant l'intégration de la supervision.

FTPS

Le serveur FTP a été configuré pour n'accepter que des connexions chiffrées (FTPS) grâce à l'option force_local_logins_ssl=YES de vsftpd, ce qui a été vérifié avec FileZilla : la connexion FTP en clair est catégoriquement refusée.

```
jojo@debian:~$ sudo systemctl status vsftpd
● vsftpd.service - vsftpd FTP server
     Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled>
     Active: active (running) since Fri 2026-06-19 15:21:49 CEST; 27>
 Invocation: 0e2c75440827462fa88792f783781dc8
   Main PID: 962 (vsftpd)
      Tasks: 1 (limit: 2297)
     Memory: 1.6M (peak: 1.8M)
        CPU: 13ms
     CGroup: /system.slice/vsftpd.service
             └─962 /usr/sbin/vsftpd /etc/vsftpd.conf

juin 19 15:21:49 debian systemd[1]: Starting vsftpd.service - vsftpd>
juin 19 15:21:49 debian systemd[1]: Started vsftpd.service - vsftpd >
lines 1-13/13 (END)
```

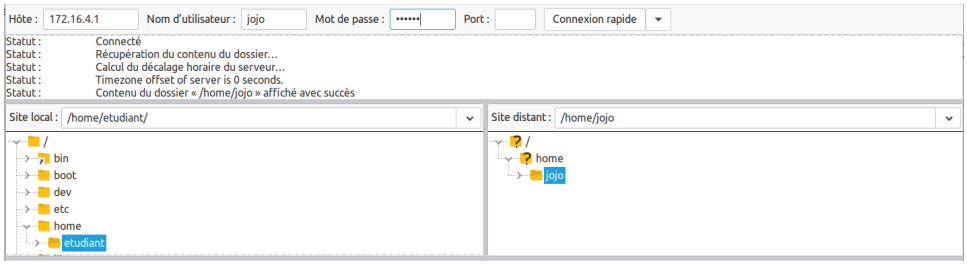
État du service vsftpd

Le service FTP vsftpd est actif (running).

```
jojo@debian:~$ cat -n /etc/vsftpd.conf
     1  listen=YES
     2  listen_ipv6=NO
     3  anonymous_enable=YES
     4  anon_upload_enable=NO
     5  local_enable=YES
     6  write_enable=YES
     7  dirmessage_enable=YES
     8  use_localtime=YES
     9  xferlog_enable=YES
    10  connect_from_port_20=YES
    11  secure_chroot_dir=/var/run/vsftpd/empty
    12  pam_service_name=vsftpd
    13  rsa_cert_file=/etc/ssl/certs/apache.crt
    14  rsa_private_key_file=/etc/ssl/private/apache.key
    15  ssl_enable=YES
    16  allow_anon_ssl=YES
    17  force_local_data_ssl=YES
    18  force_local_logins_ssl=YES
    19  ssl_tlsv1=YES
jojo@debian:~$
```

Durcissement FTP — chiffrement obligatoire

Le fichier vsftpd.conf impose ssl_enable=YES et force_local_logins_ssl=YES, rendant le chiffrement TLS obligatoire pour toute connexion FTP.



Connexion FTPS réussie (FileZilla)

FileZilla se connecte au serveur en FTPS, prouvant que le transfert de fichiers chiffré fonctionne.

```
etudiant@etudiant-VirtualBox:~$ ftp 172.16.4.1
Connected to 172.16.4.1.
220 (vsFTPd 3.0.5)
Name (172.16.4.1:etudiant): admin
530 Non-anonymous sessions must use encryption.
Login failed.
421 Service not available, remote server has closed connection
ftp>
```

Connexion FTP en clair refusée

Le serveur refuse la session FTP non chiffrée (« Non-anonymous sessions must use encryption »), confirmant l'obligation du FTPS.

SASL et certificats / autorité de certification

L'authentification SASL a été mise en place pour la messagerie, et une autorité de certification interne a été créée pour générer et déployer les certificats sur les différents services (Web, mail, FTPS, LDAPS), puis envoyés sur les postes clients.

```
jojo@debian:~$ cat -n /etc/postfix/sasl/smtpd.conf
     1  pwcheck_method: saslauthd
     2  mech_list: PLAIN LOGIN
     3  saslauthd_path: /var/run/saslauthd/mux
```

Configuration SASL pour Postfix

Le fichier smtpd.conf définit la méthode d'authentification SASL (saslauthd, mécanismes PLAIN/LOGIN).

```
jojo@debian:~$ grep -v '^#' /etc/default/saslauthd | grep -v '^$'
DESC="SASL Authentication Daemon"
NAME="saslauthd"
MECHANISMS="pam"
MECH_OPTIONS=""
THREADS=5
OPTIONS="-c -m /var/run/saslauthd"
START=yes
jojo@debian:~$
```

Configuration du démon saslauthd

Le service saslauthd est configuré avec le mécanisme PAM pour authentifier les utilisateurs de la messagerie.

```
jojo@debian:~$ sudo systemctl status saslauthd
● saslauthd.service - SASL Authentication Daemon
     Loaded: loaded (/usr/lib/systemd/system/saslauthd.service; enab>
     Active: active (running) since Fri 2026-06-19 15:21:48 CEST; 42>
 Invocation: 5849e8f8107b4c319b0ede44a2f9da10
```

État du service saslauthd

Le service saslauthd est actif (running), assurant l'authentification de la messagerie.

```
jojo@debian:~$ ls -l /etc/ssl/CA/
total 48
-rw-r--r-- 1 root root 1635 26 mai   18:54 apache.crt
-rw-r--r-- 1 root root  993 26 mai   18:54 apache.csr
-rw------- 1 root root 1704 26 mai   18:52 apache.key
-rw-r--r-- 1 root root 2000 26 mai   18:51 ca.crt
-rw------- 1 root root 3268 26 mai   18:50 ca.key
-rw-r--r-- 1 root root   41  8 juin  15:34 ca.srl
-rw-r--r-- 1 root root 1635  8 juin  15:34 dovecot.crt
-rw-r--r-- 1 root root  993  8 juin  15:33 dovecot.csr
-rw------- 1 root root 1704  8 juin  15:32 dovecot.key
-rw-r--r-- 1 root root 1635 26 mai   18:58 postfix.crt
-rw-r--r-- 1 root root  993 26 mai   18:58 postfix.csr
-rw------- 1 root root 1704 26 mai   18:57 postfix.key
jojo@debian:~$
```

Certificats de l'autorité interne

Le répertoire /etc/ssl/CA regroupe les certificats générés (Apache, Dovecot, Postfix, CA) pour sécuriser les services.

```
jojo@debian:~$ sudo ls -l /etc/ssl/private/ | grep -E "apache|postfix
|dovecot"
-rw------- 1 root root     1704 26 mai   18:54 apache.key
-rw------- 1 root root     1704  8 juin  15:34 dovecot.key
-rw-r----- 1 root postfix  1704 26 mai   18:58 postfix.key
jojo@debian:~$
```

Clés privées des services

Les clés privées des services (Apache, Dovecot, Postfix) sont protégées avec des droits restreints (lecture root uniquement).

```
jojo@debian:~$ cat /etc/ssl/CA/ca.crt
-----BEGIN CERTIFICATE-----
MIIFlzCCA3+gAwIBAgIUZXJXzTfTnnRLUh6hJdpAcrgn5SUwDQYJKoZIhvcNAQEL
BQAwWzELMAkGA1UEBhMCRlIxEjAQBgNVBAgMCUJvdXJnb2duZTEQMA4GA1UEBwwH
QXV4ZXJyZTEUMBIGA1UECgwLSVVUIEF1eGVycmUxEDAOBgNVBAMMB0NBLURNWjQw
HhcNMjYwNTI2MTY1MTQ2WhcNMzYwNTIzMTY1MTQ2WjBbMQswCQYDVQQGEwJGUjES
MBAGA1UECAwJQm91cmdvZ25lMRAwDgYDVQQHDAdBdXhlcnJlMRQwEgYDVQQKDAtJ
VVQgQXV4ZXJyZTEQMA4GA1UEAwwHQ0EtRE1aNDCCAiIwDQYJKoZIhvcNAQEBBQAD
ggIPADCCAgoCggIBAI4cl3Hs+OlrykbxHLCA2z2xql+eVdIgKbVHrYfVHcUHpGaI
HCDqcytj7PKA2HIHrQ+OxoaTxAJzk4cxeioDsnDpWuuf9JAzSTt3EAPqcngSGO9Q
qoWFppil0Zs8a9IdElVqBBPlhDLb2l+BylHTF6cvJTkRdsurMDs6uoGb0jh3/1HQ
cxNI4Jr4vd5eFvww9Zuqwf2BcUTr11zsZNaq+sq6GOD5Xydnpa4+ctRmK1v8kngF
ZzWbs0WVduBi27HRR5LkLsB3I2iYLrXzV3CYnpeCo4ABsUJWDs+jC6lXYtFQw42R
XrRa0BhZXd/AOHTVS2v8Dbyq0fY5eAAaTtd/Pln/xbWEcQ1WkcTrzzNL7ThRKLCC
EIdixMzSw6kCTZOhSma3RuBy8h6yicr5aY60J9+U4IdOovAf72nd4z9g9RdKGTbi
LkFtdVtooacJecFgzkY2xsaPNGX+332sLmwExlXRPabkBTA6olQGK5nLyayfNE7Q
JhdZecyK4rh3fUJRkeEKh+vkGyJnu13VmsUIsBWKtNqC1YFPt7j0fY8zVxMVW6aQ
0/JAnSbgnExq6HClCd/Oay5bXsIU/Khj09t6RsvcIVJQ3ZbJN0HysjEAmA+7RawZ
GZcKwtikxj110Te5vk8CsFPj4+s2kw1zrc2igX4ZMmlMvLaP2pYkD7j9USvlAgMB
AAGjUzBRMB0GA1UdDgQWBBR5xe4POstgPTaNUisFyoPTTwWeJDAfBgNVHSMEGDAW
gBR5xe4POstgPTaNUisFyoPTTwWeJDAPBgNVHRMBAf8EBTADAQH/MA0GCSqGSIb3
DQEBCwUAA4ICAQB1+TT2PTffjuB2ZBhr72oeb1RNzpAvzjln0L6k4ne0yrAQqjRo
```

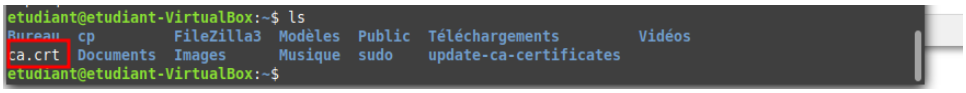
Certificat de l'autorité (CA)

Le certificat racine de l'autorité de certification interne est affiché au format PEM.

```
jojo@debian:~$ openssl x509 -in /etc/ssl/CA/ca.crt -noout -text
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            65:72:57:cd:37:d3:9e:74:4b:52:1e:a1:25:da:40:72:b8:27:e5:
25
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=FR, ST=Bourgogne, L=Auxerre, O=IUT Auxerre, CN=CA-D
MZ4
        Validity
            Not Before: May 26 16:51:46 2026 GMT
            Not After : May 23 16:51:46 2036 GMT
        Subject: C=FR, ST=Bourgogne, L=Auxerre, O=IUT Auxerre, CN=CA-
DMZ4
        Subject Public Key Info:
```

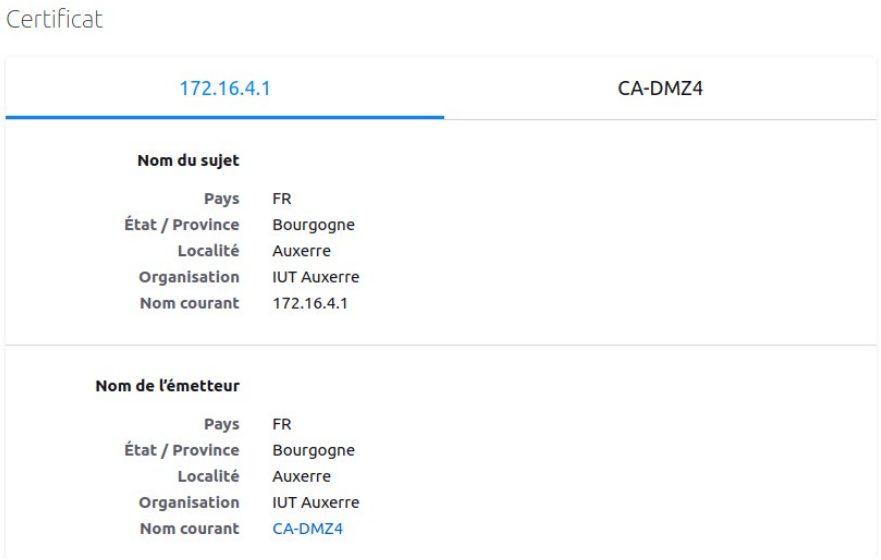
Détails du certificat de l'autorité

Le décodage du certificat montre l'émetteur CA-DMZ4 et sa période de validité, confirmant une CA interne valide.



Déploiement du certificat sur le client

Le certificat de la CA est installé sur le poste client (update-ca-certificates) pour qu'il fasse confiance aux services internes.



Vérification du certificat côté client

Le client reconnaît le certificat du serveur (172.16.4.1) délivré par l'autorité CA-DMZ4, validant la chaîne de confiance.

3.4. Switch Cisco (VLAN et trunk)

Le commutateur Cisco C1000 a été configuré avec deux VLAN : le VLAN 10 (LAN, ports 1 à 6) et le VLAN 20 (DMZ, ports 7 à 12), reliés au pare-feu Stormshield via un lien trunk sur le port 24. Les captures ci-dessous correspondent à la vérification de cette configuration de base (avant l'application des mesures de sécurisation avancées détaillées au chapitre 5).

```
Switch_4#sh spanning-tree

VLAN0010
  Spanning tree enabled protocol rstp
  Root ID    Priority    32778
             Address     9c66.976e.8e00
             This bridge is the root
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32778  (priority 32768 sys-id-ext 10)
             Address     9c66.976e.8e00
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  300 sec

Interface           Role Sts Cost      Prio.Nbr Type
------------------- ---- --- --------- -------- --------------------------------
Gi1/0/1             Desg FWD 4         128.1    P2p Peer(STP)
Gi1/0/24            Desg FWD 4         128.24   P2p


VLAN0020
  Spanning tree enabled protocol rstp
  Root ID    Priority    32788
             Address     9c66.976e.8e00
             This bridge is the root
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec

  Bridge ID  Priority    32788  (priority 32768 sys-id-ext 20)
             Address     9c66.976e.8e00
             Hello Time   2 sec  Max Age 20 sec  Forward Delay 15 sec
             Aging Time  300 sec

Interface           Role Sts Cost      Prio.Nbr Type
------------------- ---- --- --------- -------- --------------------------------
Gi1/0/11            Desg FWD 4         128.11   P2p
Gi1/0/24            Desg FWD 4         128.24   P2p


Switch_4#
```

Arbre Spanning-Tree du commutateur

Le commutateur exécute RSTP sur les VLAN 10 et 20, évitant les boucles réseau.

```
Switch_4#sh vl br

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Gi1/0/13, Gi1/0/14, Gi1/0/15
                                                Gi1/0/16, Gi1/0/17, Gi1/0/18
                                                Gi1/0/19, Gi1/0/20, Gi1/0/21
                                                Gi1/0/22, Gi1/0/23, Gi1/0/25
                                                Gi1/0/26, Gi1/0/27, Gi1/0/28
10   LAN4                             active    Gi1/0/1, Gi1/0/2, Gi1/0/3
                                                Gi1/0/4, Gi1/0/5, Gi1/0/6
20   DMZ4                             active    Gi1/0/7, Gi1/0/8, Gi1/0/9
                                                Gi1/0/10, Gi1/0/11, Gi1/0/12
```

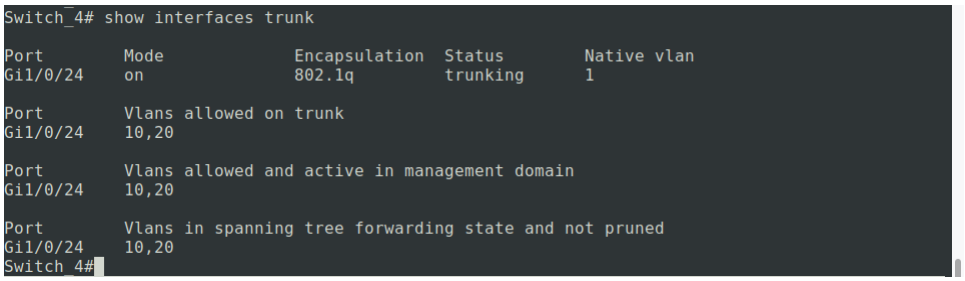
Configuration des VLAN du commutateur

Les VLAN 10 (LAN4) et 20 (DMZ4) sont créés et associés aux bons ports, assurant la segmentation du réseau.

```
Port      Name               Status       Vlan       Duplex  Speed Type
Gi1/0/1                      connected    10         a-full a-1000 10/100/1000BaseTX
Gi1/0/2                      notconnect   10           auto   auto 10/100/1000BaseTX
Gi1/0/3                      notconnect   10           auto   auto 10/100/1000BaseTX
Gi1/0/4                      notconnect   10           auto   auto 10/100/1000BaseTX
Gi1/0/5                      notconnect   10           auto   auto 10/100/1000BaseTX
Gi1/0/6                      notconnect   10           auto   auto 10/100/1000BaseTX
Gi1/0/7                      notconnect   20           auto   auto 10/100/1000BaseTX
Gi1/0/8                      notconnect   20           auto   auto 10/100/1000BaseTX
Gi1/0/9                      notconnect   20           auto   auto 10/100/1000BaseTX
Gi1/0/10                     notconnect   20           auto   auto 10/100/1000BaseTX
Gi1/0/11                     connected    20         a-full a-1000 10/100/1000BaseTX
```

État des interfaces du commutateur

Les ports sont correctement répartis entre le VLAN 10 et le VLAN 20 selon le plan défini.



Lien trunk vers le pare-feu

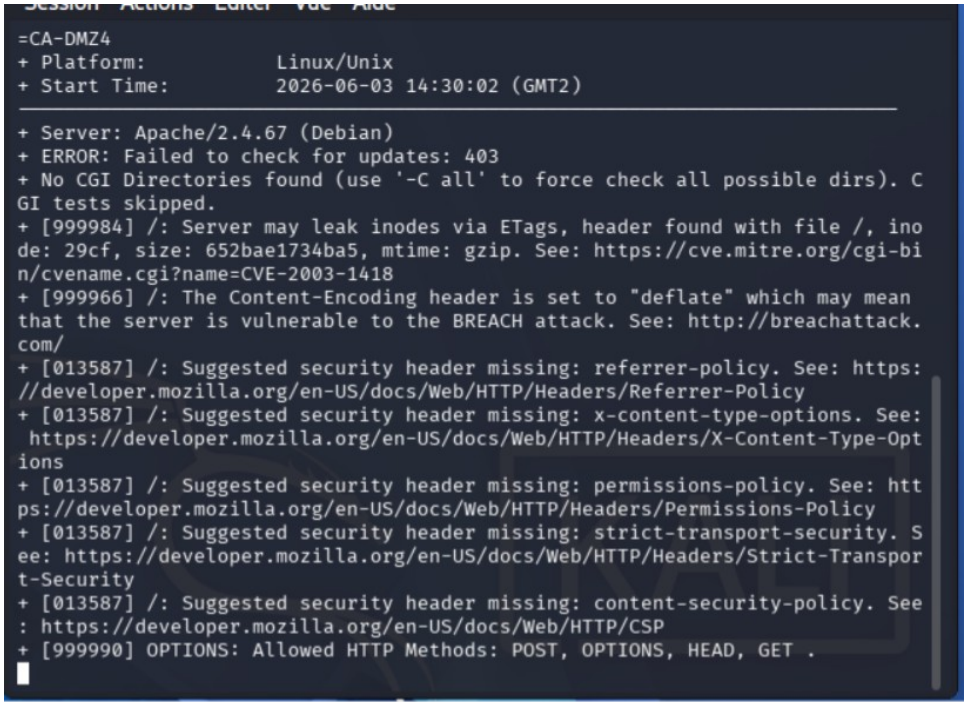
Le port Gi1/0/24 est configuré en trunk 802.1q transportant les VLAN 10 et 20 vers le pare-feu.

4. Tests d'intrusion — avant sécurisation

Une fois l'infrastructure installée et opérationnelle, une première campagne de tests d'intrusion a été menée depuis une machine Kali afin d'évaluer le niveau de sécurité initial de chaque équipement et service, avant l'application de toute contre-mesure.

Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto

Afin d'évaluer le niveau de sécurité du serveur Web Apache, un scan de vulnérabilités a été réalisé à l'aide de l'outil Nikto. Cette analyse a permis d'identifier plusieurs faiblesses de configuration, notamment l'absence de certains en-têtes HTTP de sécurité, la présence d'ETags ainsi que la divulgation d'informations sur le serveur Web.

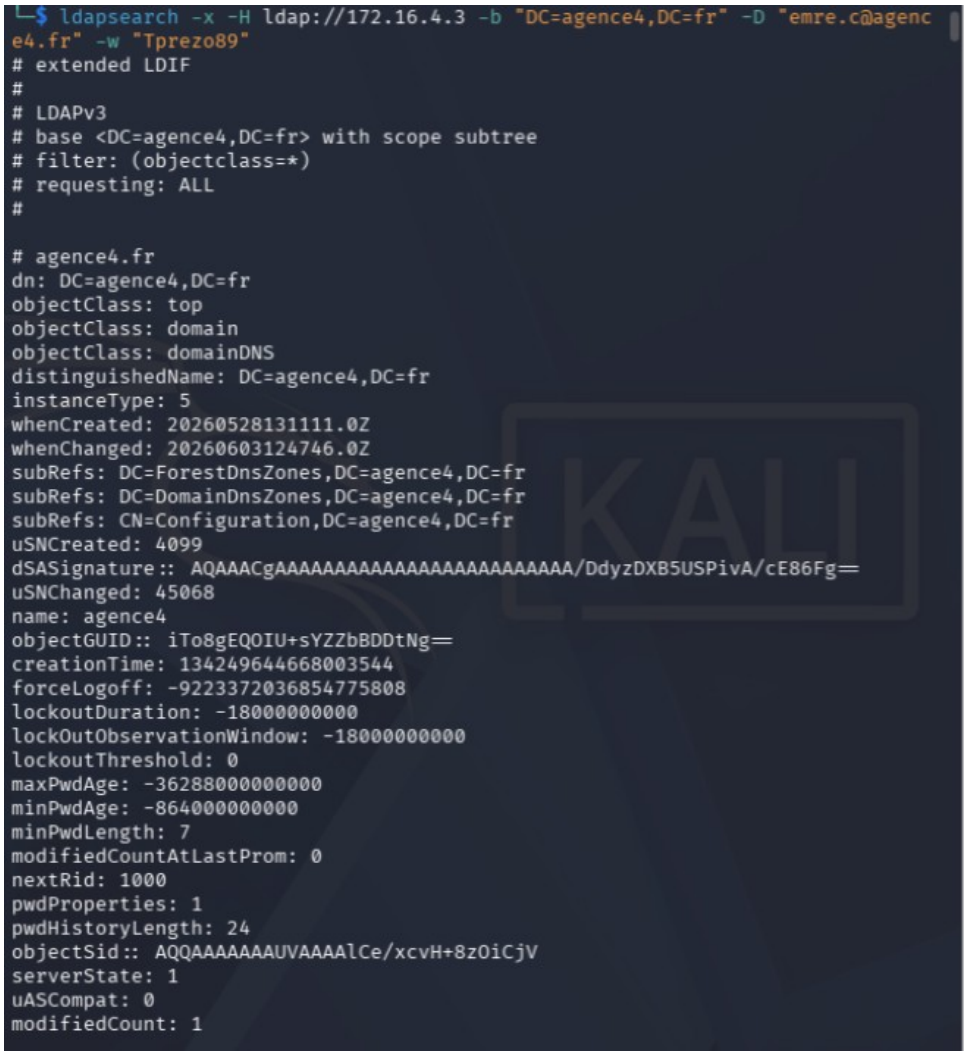


Scan Nikto — état initial du serveur Web

Le scan révèle l'absence des en-têtes HTTP de sécurité (HSTS, CSP, X-Frame-Options…) et une vulnérabilité XSS sur /user.php, exposant le serveur au clickjacking et au XSS.

Attaque n°2 : Énumération LDAP

Une énumération LDAP a été réalisée à l'aide d'un compte utilisateur standard du domaine. Cette attaque a permis de récupérer de nombreuses informations sur la structure Active Directory, les unités d'organisation et les objets présents dans l'annuaire.



Énumération LDAP en clair

Avec un simple compte, ldapsearch récupère toute la structure de l'annuaire Active Directory en clair, ce qui constitue une fuite d'information majeure.

Attaque n°3 : AS-REP Roasting

Une attaque de type AS-REP Roasting a été menée contre un compte Active Directory configuré sans pré-authentification Kerberos. Cette vulnérabilité a permis de récupérer un hash Kerberos qui a ensuite été cassé hors ligne afin de retrouver le mot de passe du compte utilisateur.

L'outil Impacket GetNPUsers a permis d'extraire un ticket Kerberos associé à un compte configuré sans pré-authentification.

```
┌──(kali㉿kali)-[~/Bureau]
└─$ impacket-GetNPUsers agence4.fr/emre.c -dc-ip 172.16.4.3 -no-pass
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for emre.c
$krb5asrep$23$emre.c@AGENCE4.FR:82c968b9df1ffbad0cb7dcdc4e5bc122$26409ce61cf5
bfbb3131cf29a3089d92db14fbc7611062bb97f81bca5968ef0ad5503c64350b8ba84b77fd38d
593cebca97f5308916f477b5abdc2a749e4287d1bd9154d5c2efa335c50d18b22131bff701cd4
5964d5eb172d48286b289b6a9250f9e7794645163e0d7267203e7f6f803cad0e34590ddfdf1a9
35f9ccd5a63d26a38d3ac9ca0ea352ce1eafd7901ecac65f0173c19fd17cf5dc7a47943d156a6
eedc66f1b47b9ac7950336b48d96eea9fff74933e2f0d682a97f987bd236b15f3cca7259565fd
e21c95ba72a7d37268266fb5e9871903713bb6b7cbd6fbe11db1bf338ffbec51762
```

Récupération du ticket AS-REP

L'outil impacket-GetNPUsers extrait un ticket Kerberos AS-REP d'un compte sans pré-authentification, exploitable hors ligne.

Le hash récupéré a ensuite été soumis à John The Ripper afin de tenter de retrouver le mot de passe associé

```
┌──(kali㉿kali)-[~/Bureau]
└─$ john --wordlist=custom.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC
-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x])
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 1 candidate left, minimum 8 needed for performance.
Tprezo89         ($krb5asrep$23$emre.c@AGENCE4.FR)
1g 0:00:00:00 DONE (2026-06-08 15:35) 11.11g/s 11.11p/s 11.11c/s 11.11C/s Tpr
ezo89
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Cassage du mot de passe (John)

John the Ripper casse le hash récupéré et retrouve le mot de passe du compte, démontrant l'impact de l'absence de pré-authentification.

Attaque n°4 : DHCP Rogue

Un serveur DHCP malveillant a été déployé à l'aide de dnsmasq afin de distribuer de faux paramètres réseau aux postes clients. L'attaque a réussi et le poste de test a obtenu une adresse IP provenant du serveur frauduleux.

```
 GNU nano 8.7.1                                  /etc/dnsmasq.conf

interface=eth0
dhcp-range=192.168.4.100,192.168.4.200,12h
dhcp-option=3,192.168.4.50
dhcp-option=6,192.168.4.50
```

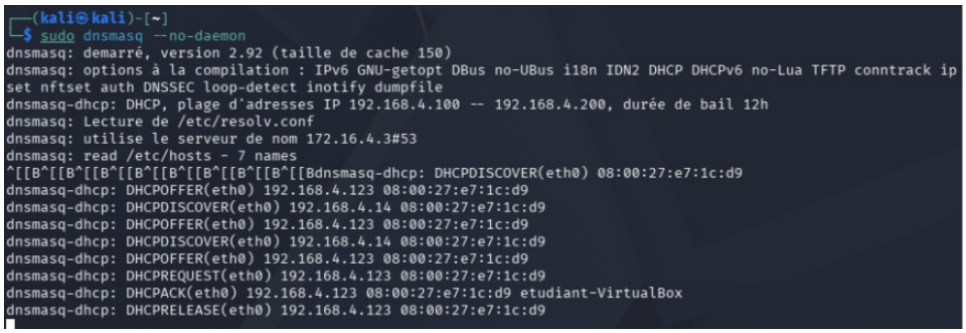
Configuration du faux serveur DHCP

Le fichier dnsmasq.conf configure un serveur DHCP pirate distribuant une plage d'adresses frauduleuse.

Un serveur DHCP frauduleux a été configuré sur la machine Kali à l'aide de dnsmasq afin de distribuer de faux paramètres réseau aux postes clients.

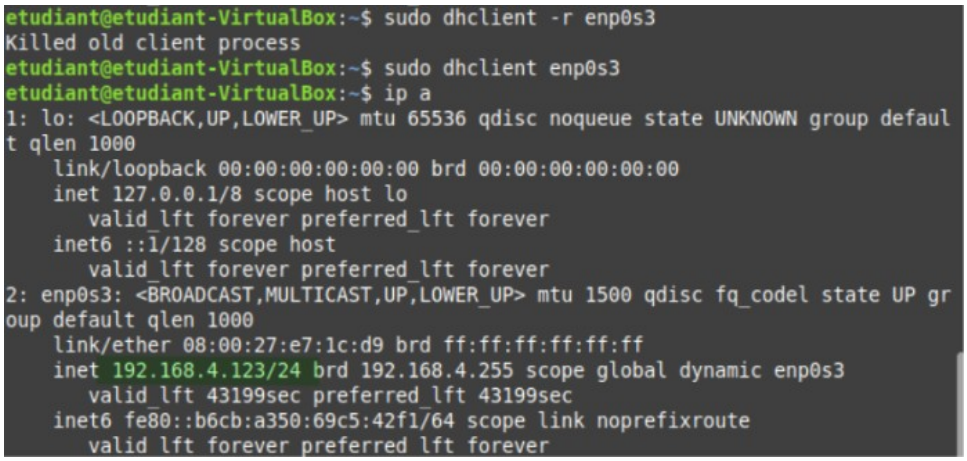
Une fois le service démarré, les requêtes DHCP émises par le poste client ont été interceptées par le serveur malveillant qui lui a attribué une adresse IP issue de la fausse plage configurée

Le renouvellement du bail DHCP sur le poste victime confirme que la configuration réseau reçue provient désormais du serveur frauduleux.



Lancement du DHCP pirate

Le faux serveur DHCP répond aux requêtes (DHCPOFFER) avec une configuration réseau malveillante.



Client victime piégé par le DHCP pirate

Le poste client obtient une adresse IP issue du faux serveur, confirmant la réussite de l'attaque avant sécurisation.

Attaque n°5 : MAC Flooding

Une attaque de type MAC Flooding a été réalisée à l'aide de l'outil macof afin de saturer la table MAC du commutateur. L'équipement a enregistré plusieurs milliers d'adresses MAC frauduleuses en quelques secondes.

Dans un premier temps, l'état de la table MAC du commutateur a été relevé afin d'obtenir une référence avant l'attaque.

```
Switch#show mac address-table count

Mac Entries for Vlan 10:
---------------------------
Dynamic Address Count  : 4
Static  Address Count  : 0
Total Mac Addresses    : 4

Mac Entries for Vlan 20:
---------------------------
Dynamic Address Count  : 4
Static  Address Count  : 0
Total Mac Addresses    : 4

Total Mac Address Space Available: 15350
```

Table MAC avant l'attaque

L'état initial de la table d'adresses MAC du commutateur sert de référence (4 adresses).

L'outil macof a ensuite été utilisé afin d'envoyer plusieurs milliers d'adresses MAC aléatoires vers le commutateur.

```
┌──(kali㉿kali)-[~]
└─$ sudo macof -i eth0
65:33:38:d:17:c4 6f:2:d6:44:a1:8
5a:f7:7:57:9e:ee 8:24:33:4d:91:7
```

Lancement du MAC Flooding (macof)

L'outil macof génère des milliers d'adresses MAC aléatoires pour saturer la table du commutateur.

Après quelques secondes, une nouvelle vérification de la table MAC a permis de constater l'apparition d'un très grand nombre d'adresses frauduleuses.

```
Switch#show mac address-table count

Mac Entries for Vlan 10:
---------------------------
Dynamic Address Count  : 15354
Static  Address Count  : 0
Total Mac Addresses    : 15354

Mac Entries for Vlan 20:
---------------------------
Dynamic Address Count  : 4
Static  Address Count  : 0
Total Mac Addresses    : 4

Total Mac Address Space Available: 0
```

Table MAC saturée

La table MAC explose (plus de 15 000 entrées), confirmant la réussite de l'attaque et le risque de basculement du switch en mode diffusion.

Attaque n°6 : ARP Spoofing

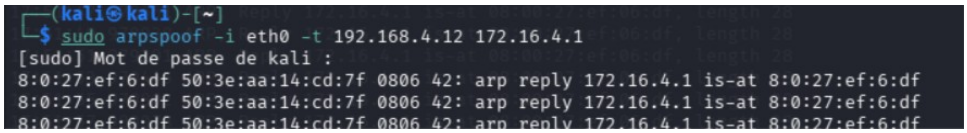
Une attaque de type Man-in-the-Middle a été réalisée à l'aide d'ARP Spoofing. Le trafic du poste victime a pu être redirigé vers la machine Kali, permettant l'interception des communications réseau.



Activation du routage pour l'ARP Spoofing

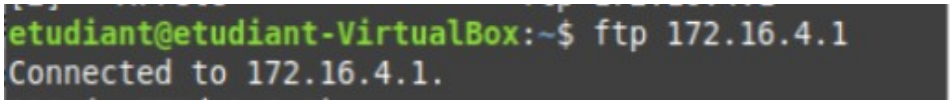
L'attaquant active le routage IP afin de relayer le trafic intercepté lors de l'attaque Man-in-the-Middle.

Après avoir activé le routage IP sur la machine attaquante, l'outil arpspoof a été utilisé afin d'usurper les adresses MAC de la passerelle et de la victime. Cette technique permet à l'attaquant de se positionner entre les deux équipements



Usurpation ARP (arpspoof)

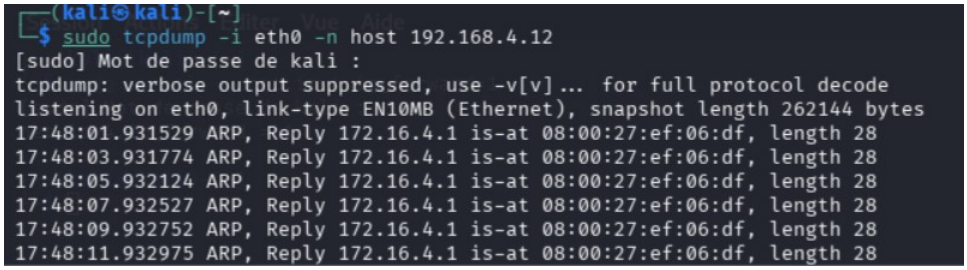
L'outil arpspoof usurpe les adresses MAC de la passerelle et de la victime pour se placer au milieu des communications.



Interception du trafic

Le trafic de la victime transite désormais par la machine attaquante.

Une fois l'attaque en place, le trafic réseau a été observé à l'aide de tcpdump afin de vérifier que les communications transitaient bien par la machine Kali.



Capture du trafic redirigé (tcpdump)

tcpdump confirme que les paquets de la victime passent bien par la machine Kali, validant l'attaque MitM avant sécurisation.

```
Switch_4#show ip arp inspection vlan 10

Source Mac Validation      : Disabled
Destination Mac Validation : Disabled
IP Address Validation      : Disabled

 Vlan     Configuration    Operation   ACL Match          Static ACL
 ----     -------------    ---------   ---------          ----------
   10     Enabled          Active

 Vlan     ACL Logging      DHCP Logging      Probe Logging
 ----     -----------      ------------      -------------
   10     Deny             Deny              Off
Switch_4#
```

État de l'ARP Inspection

La commande show ip arp inspection montre l'état du mécanisme de protection ARP sur le VLAN 10.

Attaque n°7 : Scan Nmap des services Linux

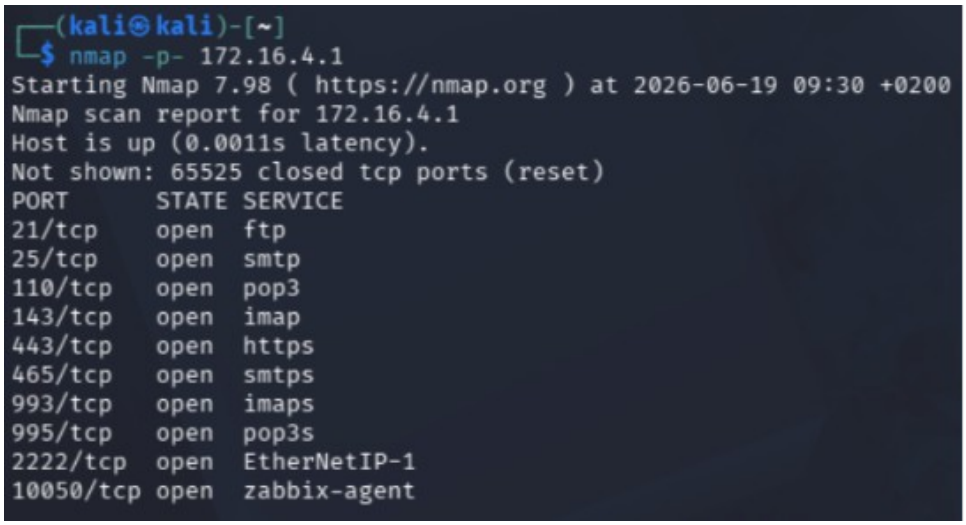
Afin d'identifier les services exposés sur le serveur Linux, un scan Nmap a été réalisé depuis la machine Kali. Cette analyse permet de détecter les ports ouverts ainsi que les versions des services accessibles depuis le réseau.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 172.16.4.1
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-19 09:22 +0200
Nmap scan report for 172.16.4.1
Host is up (0.0011s latency).
Not shown: 991 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
21/tcp   open  ftp      vsftpd 3.0.5
25/tcp   open  smtp     Postfix smtpd
110/tcp  open  pop3     Dovecot pop3d
143/tcp  open  imap     Dovecot imapd
443/tcp  open  ssl/http Apache httpd 2.4.67 ((Debian))
465/tcp  open  ssl/smtp Postfix smtpd
993/tcp  open  ssl/imap Dovecot imapd
995/tcp  open  ssl/pop3 Dovecot pop3d
2222/tcp open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
Service Info: Host:  debian; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Scan Nmap des services Linux

Le scan révèle plusieurs services exposés (FTP, SMTP, POP3, IMAP, HTTPS, SSH…), dont certains inutiles susceptibles d'être exploités.

Le scan a révélé la présence de plusieurs services accessibles, notamment HTTP sur le port 80, SMTP sur le port 25 ainsi que différentes informations de version susceptibles d'être exploitées lors d'une phase de reconnaissance.

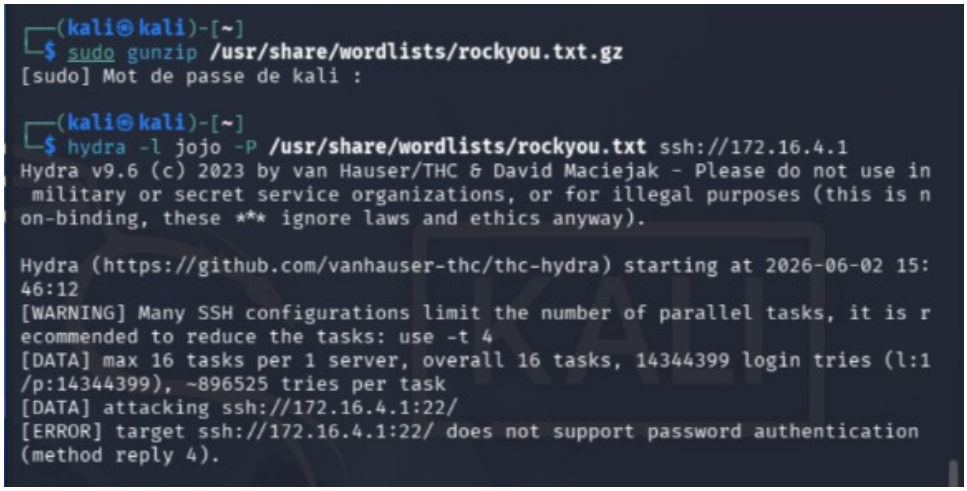


Scan Nmap de tous les ports

Le scan complet des ports confirme les services ouverts, y compris l'agent Zabbix (10050).

Attaque n°8 : Vérification des protections SSH

Une tentative de brute force SSH a été réalisée à l'aide de l'outil Hydra et de la liste de mots de passe rockyou.txt. L'objectif était de vérifier si un attaquant pouvait compromettre un compte utilisateur par force brute.



Brute force SSH (Hydra)

La tentative de brute force échoue : le serveur n'accepte pas l'authentification par mot de passe, rendant l'attaque inopérante.

[ERROR] target ssh://172.16.4.1:22/ does not support password authentication

Le bruteforce SSH a échoué grace à l'auth par mot de passe. La sécurisation fonctionne

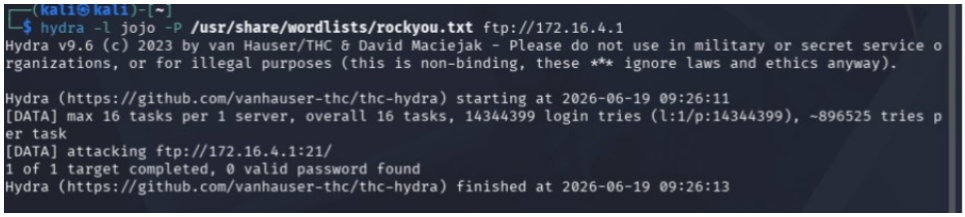
La tentative a échoué immédiatement car le serveur SSH n'accepte plus l'authentification par mot de passe. Seule l'authentification par clé est autorisée.

Cette protection empêche efficacement les attaques de type brute force visant les comptes SSH.

Attaque n°9 : Vérification des protections FTP

Une attaque par force brute a également été menée contre le service FTP afin de vérifier la résistance du serveur face aux tentatives d'authentification automatisées.

Les essais ont échoué car le protocole FTP classique a été désactivé au profit du protocole sécurisé FTPS.



Brute force FTP (Hydra)

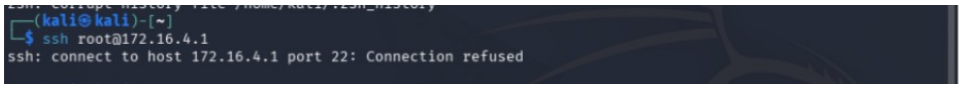
La tentative de brute force FTP ne trouve aucun mot de passe valide, le FTP en clair étant désactivé au profit du FTPS.

L'absence de service FTP non chiffré empêche l'exploitation de cette attaque.

Attaque n°10 : Vérification de l'accès root SSH

Une tentative de connexion directe au compte administrateur root a été effectuée depuis la machine Kali afin de vérifier l'application des mesures de durcissement SSH.

Le serveur a refusé la connexion conformément à la directive « PermitRootLogin no » configurée dans le fichier sshd_config.



Tentative de connexion root SSH

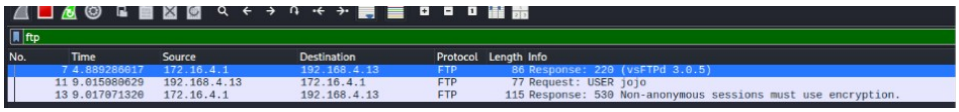
La connexion directe au compte root est refusée (port 22 fermé / PermitRootLogin no), bloquant l'accès au compte le plus privilégié.

Cette mesure réduit fortement les risques de compromission du compte administrateur principal.

Attaque n°11 : Vérification du chiffrement des communications

Une analyse réseau a été réalisée à l'aide de Wireshark afin de vérifier que les communications entre les clients et le serveur étaient correctement chiffrées.

Les tests réalisés sur FTP montrent que le serveur refuse systématiquement les connexions non chiffrées grâce à force_local_logins_ssl=YES dans notre config vsftpd



Analyse FTP avec Wireshark

La capture montre que le serveur impose le chiffrement (réponse 530), confirmant le refus des sessions FTP en clair.

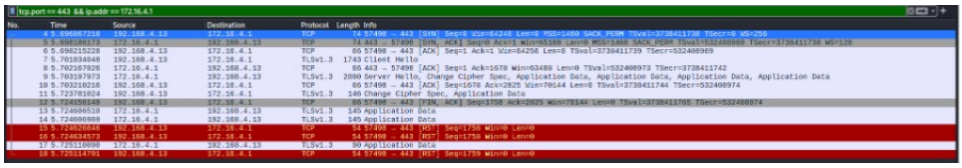
Des tests HTTPS ont ensuite été effectués à l'aide de curl et Wireshark afin de vérifier la présence du protocole TLS lors de l'établissement de la connexion.

Les échanges observés dans Wireshark confirment l'utilisation du protocole TLS, garantissant la confidentialité des données échangées entre les clients et le serveur.



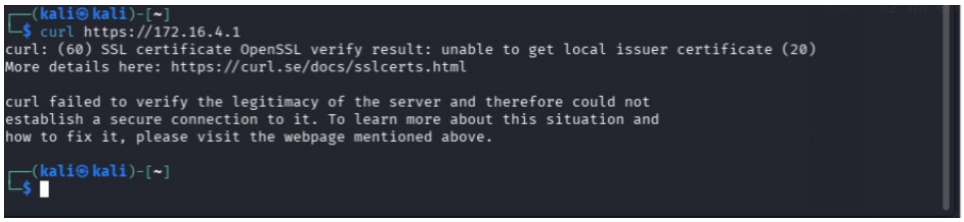
Vérification de la fermeture du HTTP

La requête curl en HTTP échoue (port 80 inaccessible), confirmant que seul le HTTPS est disponible.



Capture du handshake TLS (Wireshark)

La capture met en évidence l'établissement d'une connexion chiffrée TLS sur le port 443.

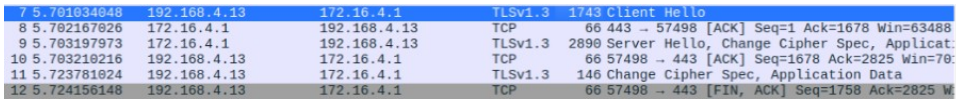


Vérification du certificat (curl)

L'erreur « unable to get local issuer certificate » prouve que la connexion exige un certificat reconnu : c'est une preuve supplémentaire de sécurité.

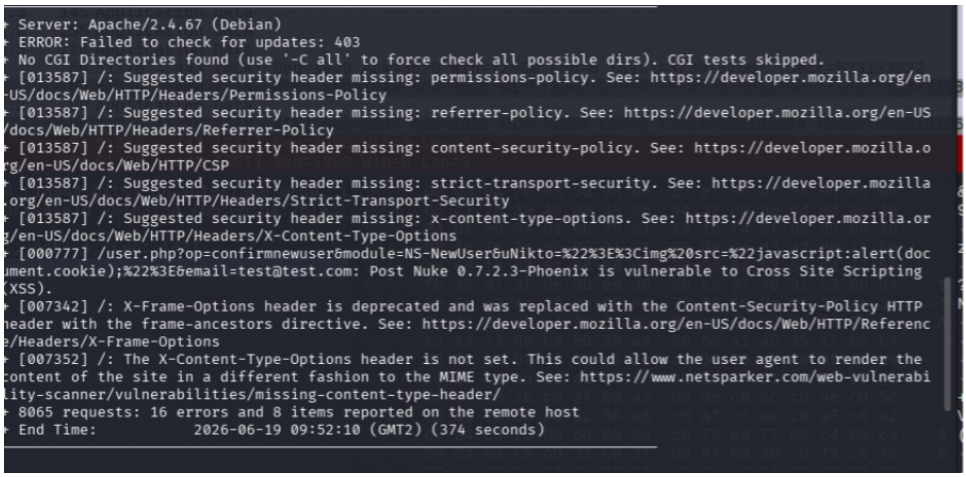
Curl : L'erreur unable to get local issuer certificate est normale car curl ne connaît pas ta CA. Sans le flag -k, curl refuse même de se connecter à un certificat non reconnu — c'est en fait une preuve supplémentaire de sécurité.

On voit bien l'encryption en tls:



Confirmation du chiffrement TLS 1.3

La capture Wireshark montre le Client Hello et le Change Cipher Spec TLS 1.3, confirmant que les échanges sont bien chiffrés.

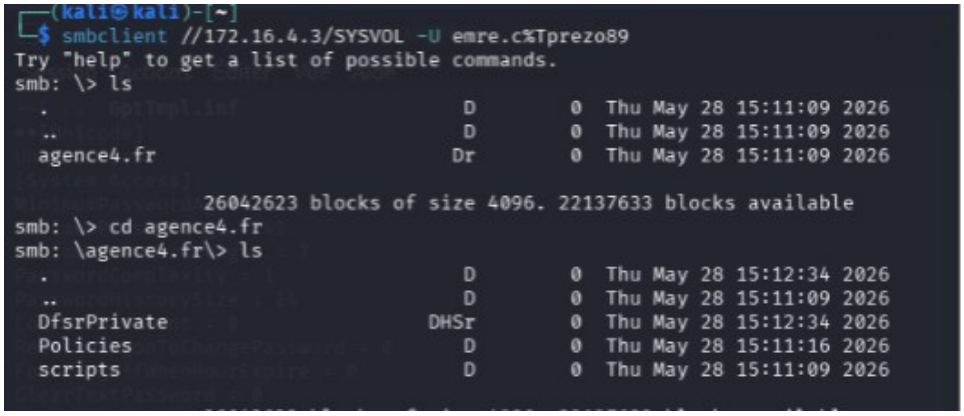


Analyse complète Nikto du serveur Web

Le rapport Nikto détaille les en-têtes manquants et la page /user.php signalée, servant de base au durcissement du serveur.

Attaque n°12 : Accès SYSVOL via SMB

Un utilisateur standard du domaine a été utilisé afin d'accéder au partage SYSVOL du contrôleur de domaine. Cette attaque vise à récupérer des informations de configuration présentes dans les stratégies de groupe.



Accès au partage SYSVOL (smbclient)

Un compte standard accède au partage SYSVOL et liste les stratégies de groupe, exposant des informations de configuration.

L'analyse du fichier GptTmpl.inf a révélé une politique de mots de passe particulièrement faible, facilitant les attaques par dictionnaire ou force brute.

```
└─$ cat GptTmpl.inf
••[Unicode]
Unicode=yes
[System Access]
MinimumPasswordAge = 1
MaximumPasswordAge = 42
MinimumPasswordLength = 7
PasswordComplexity = 1
PasswordHistorySize = 24
LockoutBadCount = 0
RequireLogonToChangePassword = 0
ForceLogoffWhenHourExpire = 0
ClearTextPassword = 0
LSAAnonymousNameLookup = 0
[Kerberos Policy]
MaxTicketAge = 10
MaxRenewAge = 7
MaxServiceAge = 600
```

Analyse de la politique de mots de passe

Le fichier GptTmpl.inf révèle la politique de mots de passe appliquée au domaine (longueur, complexité, verrouillage).

Attaque n°13 : SYN Flooding

Une attaque de déni de service a été réalisée à l'aide de l'outil hping3 afin de générer un grand volume de paquets SYN vers l'infrastructure réseau.

```
┌──(kali㉿kali)-[~]
└─$ sudo hping3 -S -c 15000 -d 1000 -w 64 -p 80 --flood --rand-source 172.16.4.1
HPING 172.16.4.1 (eth0 172.16.4.1): S set, 40 headers + 1000 data bytes
hping in flood mode, no replies will be shown
^C
── 172.16.4.1 hping statistic ──
21625795 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Lancement du SYN Flooding (hping3)

L'outil hping3 envoie un flot massif de paquets SYN avec adresses sources aléatoires vers l'infrastructure.

Les statistiques du commutateur montrent une augmentation importante du trafic réseau avec près de 338 Mbps et plusieurs dizaines de milliers de paquets par seconde.

```
Switch#sh interfaces gigabitEthernet1/0/1
GigabitEthernet1/0/1 is up, line protocol is up (connected)
  Hardware is Gigabit Ethernet, address is 9c66.976e.8e01 (bia 9c66.976e.8e01)
  MTU 1500 bytes, BW 1000000 Kbit/sec, DLY 10 usec,
```

État du port attaqué

Le port Gi1/0/1 du commutateur reste actif pendant l'attaque.

```
5 minute input rate 337916000 bits/sec, 39982 packets/sec
5 minute output rate 11000 bits/sec, 1 packets/sec
   22488716 packets input, 3094976382 bytes, 0 no buffer
   Received 1652571 broadcasts (1651977 multicasts)
```

Impact du SYN Flooding

Les statistiques montrent un trafic anormal d'environ 338 Mbps et près de 40 000 paquets/s, caractéristique d'un déni de service.

5. Mesures de sécurisation appliquées

Pour chacune des vulnérabilités identifiées lors de la première campagne de tests, une contre-mesure conforme aux recommandations de l'ANSSI a été mise en œuvre.

Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto

Afin de corriger ces vulnérabilités, la configuration Apache a été modifiée afin d'ajouter les en-têtes de sécurité manquants (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy et Permissions-Policy) et de limiter les informations divulguées par le serveur.

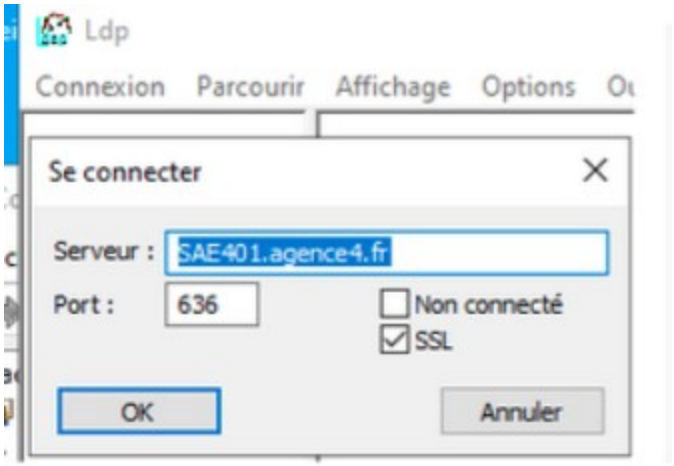
```
Header always set Strict-Transport-Security "max-age=63072000; includeSubDomains"
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "DENY"
Header always set Referrer-Policy "no-referrer"
Header always set Content-Security-Policy "default-src 'self'"
Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"
```

Ajout des en-têtes de sécurité Apache

La configuration ajoute HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, CSP et Permissions-Policy pour corriger les faiblesses détectées par Nikto.

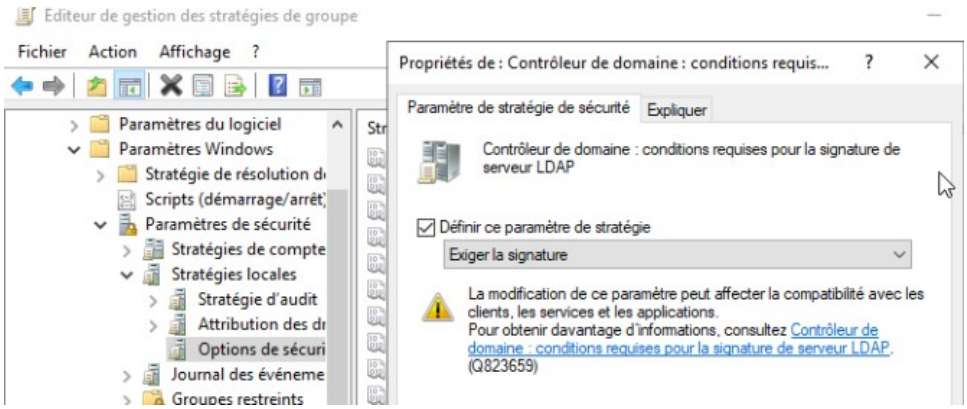
Attaque n°2 : Énumération LDAP

Afin de protéger les échanges LDAP, le protocole LDAPS a été déployé à l'aide d'un certificat délivré par l'autorité de certification du domaine. Les communications LDAP sont désormais chiffrées via TLS sur le port 636.



Déploiement de LDAPS

Une connexion sécurisée sur le port 636 avec SSL est mise en place pour chiffrer les échanges avec l'annuaire.

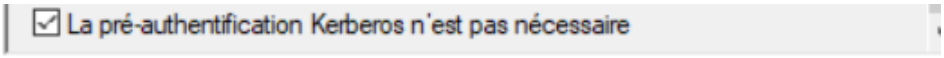


Exigence de signature LDAP/SMB

La stratégie de groupe impose la signature des communications avec le contrôleur de domaine, limitant les attaques Man-in-the-Middle.

Attaque n°3 : AS-REP Roasting

La pré-authentification Kerberos a été réactivée sur les comptes concernés afin d'empêcher la récupération des tickets AS-REP par un attaquant non authentifié.



Réactivation de la pré-authentification Kerberos

L'option « pré-authentification non nécessaire » est retirée du compte, empêchant la récupération de tickets AS-REP.

Attaque n°4 : DHCP Rogue

Le mécanisme DHCP Snooping a été activé sur le commutateur Cisco afin d'autoriser uniquement les réponses DHCP provenant des ports de confiance.

```
! On trust l interface TRUNK pour l ARP inspection et DHCP snooping
ip arp inspection trust
ip dhcp snooping trust
```

Ports de confiance (DHCP Snooping / DAI)

Le port trunk est déclaré de confiance pour le DHCP Snooping et l'ARP Inspection, autorisant uniquement les flux légitimes.

Attaque n°5 : MAC Flooding

La fonctionnalité Port Security a été activée sur les ports utilisateurs afin de limiter le nombre d'adresses MAC autorisées et de bloquer automatiquement les comportements anormaux.

```
! Ajout de la securite pour le MAC Flooding
switchport port-security
switchport port-security maximum 5
switchport port-security mac-address sticky
switchport port-security violation shutdown
```

Activation du Port Security

Le commutateur limite le nombre d'adresses MAC par port (sticky) et bloque le port en cas de violation, contrant le MAC Flooding.

Attaque n°6 : ARP Spoofing

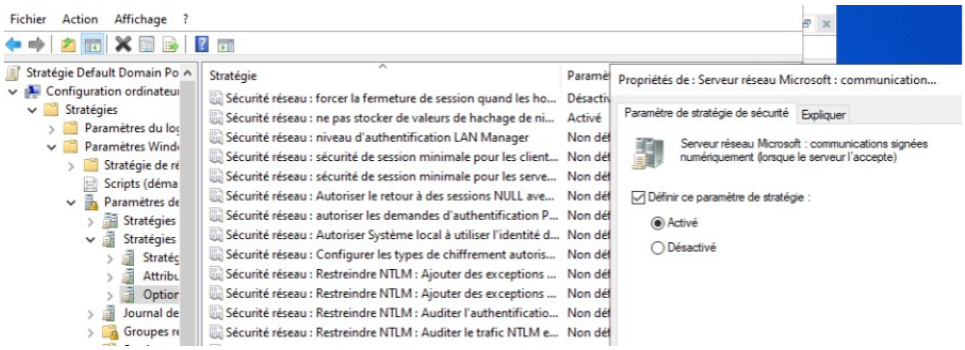
Le mécanisme Dynamic ARP Inspection (DAI) a été configuré sur le commutateur afin de vérifier la validité des réponses ARP et bloquer les annonces frauduleuses.

```
arp access-list ARP_LEGITIME
arp access-list ARP_DMZ
ip arp inspection filter ARP_LEGITIME vlan 10 static
ip arp inspection filter ARP_DMZ vlan 20 static
```

Filtres ARP légitimes (DAI)

Des listes d'accès ARP définissent les associations IP/MAC légitimes par VLAN pour le Dynamic ARP Inspection.

En complément de la protection réseau mise en place sur le commutateur, la signature SMB a été activée sur le contrôleur de domaine afin de garantir l'intégrité des échanges SMB et limiter les risques liés aux attaques de type Man-in-the-Middle.



Signature réseau obligatoire (GPO)

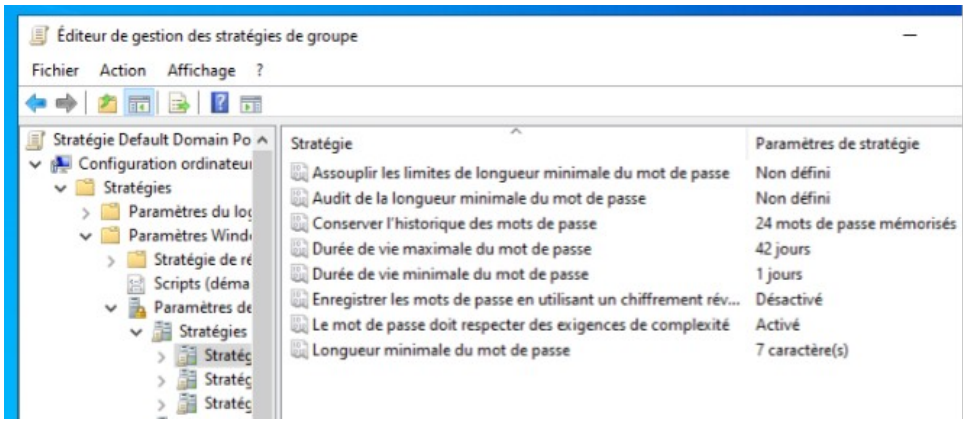
La stratégie active la signature numérique systématique des communications réseau du serveur, renforçant l'intégrité des échanges.

Attaque n°7 : Scan Nmap des services Linux

Afin de réduire la surface d'attaque, les services inutiles ont été désactivés. Le port HTTP (80) a été fermé au profit du HTTPS et le service SMTP non nécessaire a également été supprimé. Les informations divulguées par Apache ont été limitées afin de réduire les possibilités de fingerprinting.

Attaque n°12 : Accès SYSVOL via SMB

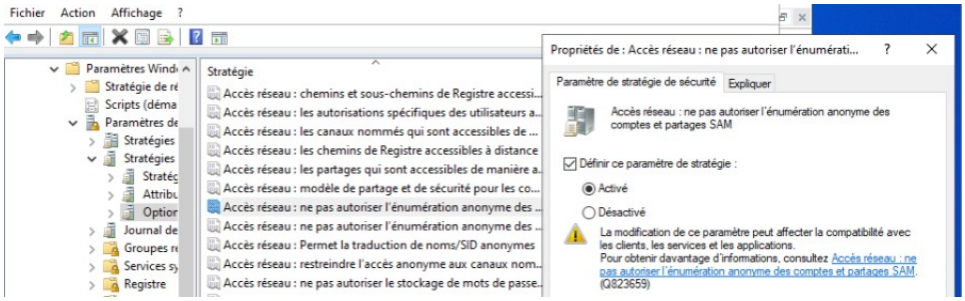
Afin de renforcer la sécurité du domaine, la stratégie de groupe a été modifiée. La longueur minimale des mots de passe a été portée à 7 caractères et un verrouillage du compte après plusieurs tentatives infructueuses a été activé.



Renforcement de la politique de mots de passe

La GPO impose une longueur minimale et des exigences de complexité, corrigeant la faiblesse découverte dans SYSVOL.

Afin de limiter les informations accessibles à un attaquant lors d'une phase de reconnaissance, l'énumération anonyme des comptes et des partages SAM a été désactivée via les stratégies de sécurité du domaine.

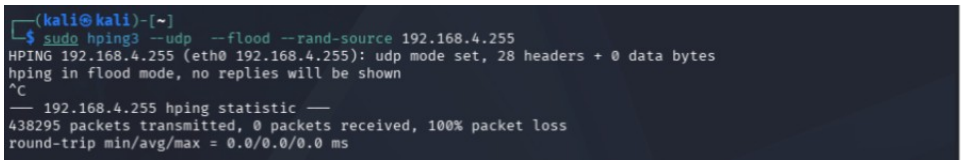


Désactivation de l'énumération anonyme

La stratégie interdit l'énumération anonyme des comptes et partages SAM, limitant la reconnaissance d'un attaquant.

Attaque n°13 : SYN Flooding

Afin de limiter l'impact de ce type d'attaque, la fonctionnalité Storm Control a été activée sur les ports du commutateur Cisco afin de détecter et limiter automatiquement les flux anormaux.



Réattaque par flood après Storm Control

La nouvelle tentative de flood se solde par 100 % de perte de paquets : le trafic anormal est bloqué par le Storm Control.

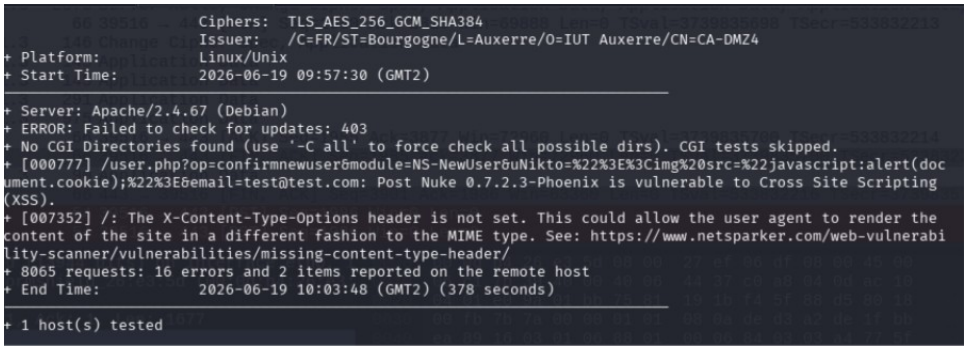
6. Tests d'intrusion après sécurisation et diagnostics

Une seconde campagne de tests d'intrusion, strictement identique à la première, a été menée après application des mesures de sécurisation afin de démontrer leur efficacité. Pour chaque attaque, un diagnostic résume la vulnérabilité initiale, son impact et le résultat obtenu après sécurisation.

6.1. Vérification après sécurisation, attaque par attaque

Attaque n°1 : Analyse de sécurité du serveur Web avec Nikto

Un nouveau scan Nikto a ensuite été réalisé afin de vérifier l'efficacité des mesures mises en place. Les principales vulnérabilités précédemment détectées n'étaient plus présentes, confirmant le renforcement de la sécurité du serveur Web.



Scan Nikto après sécurisation

Le nouveau scan ne détecte plus les en-têtes manquants : les principales vulnérabilités du serveur Web ont été corrigées.

Comme prévu, le fichier user.php n'existe pas sur le serveur. C'est un faux positif de Nikto : il teste des chemins génériques connus pour être vulnérables sur d'autres CMS (ici "Post Nuke"), mais leserveur ne l'a pas, ce n'est donc pas une vraie vulnérabilité

> Diagnostic : le scan Nikto initial a révélé l'absence des principaux en-têtes HTTP de sécurité (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) ainsi que la divulgation de la version d'Apache. Ces faiblesses exposent le serveur au clickjacking, aux attaques XSS et au fingerprinting. Après ajout des en-têtes et masquage des informations serveur, le nouveau scan ne détecte plus ces vulnérabilités : le serveur Web est durci.

Attaque n°2 : Énumération LDAP

Après la mise en place de LDAPS, les requêtes LDAP ne peuvent plus être interceptées ou consultées en clair sur le réseau, ce qui limite fortement les possibilités d'énumération de l'annuaire Active Directory.



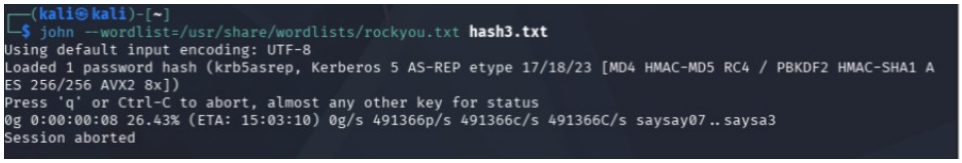
Énumération LDAP bloquée après LDAPS

La tentative ldapsearch échoue (« Can't contact LDAP server »), confirmant que l'annuaire n'est plus interrogeable en clair.

> Diagnostic : avec un simple compte utilisateur, l'annuaire Active Directory était entièrement interrogeable en clair (OU, comptes, objets), ce qui constitue une fuite d'information majeure facilitant une attaque ciblée. Le déploiement de LDAPS (TLS sur le port 636) chiffre désormais les échanges : les requêtes ne peuvent plus être interceptées en clair.

Attaque n°3 : AS-REP Roasting

Une nouvelle tentative d'attaque a été réalisée après modification de la configuration. Aucun hash exploitable n'a pu être récupéré, ce qui confirme l'efficacité de la mesure de protection mise en œuvre.



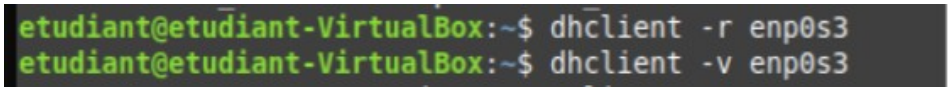
AS-REP Roasting bloqué après sécurisation

Aucun hash exploitable n'est récupéré après réactivation de la pré-authentification : l'attaque est neutralisée.

> Diagnostic : un compte configuré sans pré-authentification Kerberos permettait de récupérer un ticket AS-REP, cassé hors ligne pour retrouver le mot de passe. La réactivation de la pré-authentification Kerberos empêche désormais la récupération de ces tickets : la nouvelle tentative ne renvoie plus aucun hash exploitable.

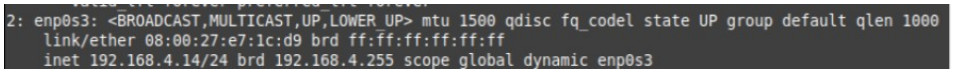
Attaque n°4 : DHCP Rogue

Une nouvelle tentative a été réalisée après activation du DHCP Snooping. Les réponses du serveur DHCP frauduleux ont été bloquées par le commutateur et le poste client n'a plus reçu de configuration réseau malveillante.



Renouvellement DHCP après sécurisation

Après activation du DHCP Snooping, le client ne reçoit plus de configuration du serveur pirate.



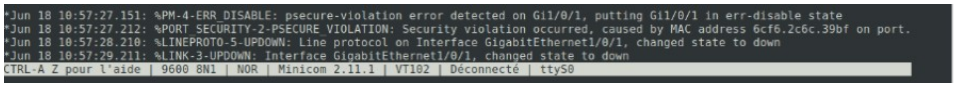
Adresse légitime obtenue par le client

Le poste client récupère une adresse IP valide du serveur DHCP légitime, le faux serveur étant bloqué.

> Diagnostic : un faux serveur DHCP (dnsmasq) parvenait à distribuer une configuration réseau frauduleuse aux clients, ouvrant la voie à des attaques de type Man-in-the-Middle. L'activation du DHCP Snooping sur le commutateur n'autorise plus que les réponses provenant des ports de confiance : le serveur pirate est bloqué.

Attaque n°5 : MAC Flooding

Une nouvelle tentative de saturation a été effectuée. Le commutateur a détecté la violation de sécurité et a automatiquement bloqué le port concerné.



Port bloqué après MAC Flooding

Le commutateur détecte la violation de sécurité et bascule automatiquement le port en err-disable, neutralisant l'attaque.

```
Switch_4#show mac address-table count

Mac Entries for Vlan 20:
---------------------------
Dynamic Address Count   : 1
Static  Address Count   : 3
Total Mac Addresses     : 4

Mac Entries for Vlan 10:
---------------------------
Dynamic Address Count   : 1
Static  Address Count   : 5
Total Mac Addresses     : 6

Total Mac Address Space Available: 15348

Switch_4#
```

Table MAC normale après sécurisation

La table MAC revient à un nombre d'adresses normal, confirmant l'efficacité du Port Security.

> Diagnostic : l'outil macof saturait en quelques secondes la table d'adresses MAC du commutateur, risquant de le faire basculer en mode hub (diffusion de tout le trafic). L'activation du Port Security limite le nombre d'adresses MAC par port et bloque automatiquement le port en cas de violation : l'attaque est neutralisée.

Attaque n°6 : ARP Spoofing

Une nouvelle tentative d'ARP Spoofing a été effectuée après l'activation de la protection. Le trafic n'a plus pu être redirigé et les paquets malveillants ont été bloqués par le commutateur.

```
etudiant@etudiant-VirtualBox:~$ ftp 172.16.4.1
Connected to 172.16.4.1.
220 (vsFTPd 3.0.5)
Name (172.16.4.1:etudiant): jojo
530 Non-anonymous sessions must use encryption.
Login failed.
421 Service not available, remote server has closed connection
ftp> zz
?Invalid command
ftp>
```

Connexion FTP en clair toujours refusée

Le serveur continue de refuser toute session FTP non chiffrée, confirmant la robustesse de la configuration FTPS.

```
┌──(kali㉿kali)-[~]
└─$ sudo tcpdump -i eth0 -n host 192.168.4.14
[sudo] Mot de passe de kali :
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

ARP Spoofing bloqué après DAI

Après activation du Dynamic ARP Inspection, le trafic n'est plus intercepté par la machine attaquante.

```
Switch_4#show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  --------------------
08:00:27:E7:1C:D9   192.168.4.14     673583      dhcp-snooping   10    GigabitEthernet1/0/1
50:3E:AA:14:CD:7F   192.168.4.12     689973      dhcp-snooping   10    GigabitEthernet1/0/1
08:00:27:EF:06:DF   192.168.4.13     689370      dhcp-snooping   10    GigabitEthernet1/0/1
08:00:27:B5:A0:4F   192.168.4.11     673576      dhcp-snooping   10    GigabitEthernet1/0/1
Total number of bindings: 4
```

Table de liaison DHCP Snooping

La table de binding associe chaque adresse MAC à son IP et son port, base du contrôle exercé par le DHCP Snooping et le DAI.



Blocage des ARP frauduleux (journaux DAI)

Les journaux du commutateur montrent les requêtes ARP invalides rejetées par le Dynamic ARP Inspection, prouvant l'efficacité de la protection.

> Diagnostic : l'usurpation des adresses MAC de la passerelle et de la victime (arpspoof) permettait d'intercepter le trafic réseau. La mise en place du Dynamic ARP Inspection (DAI), complétée par la signature SMB sur le contrôleur de domaine, vérifie la validité des réponses ARP et bloque les annonces frauduleuses : le trafic n'est plus redirigé.

Attaque n°7 : Scan Nmap des services Linux

Ici il me manque uniquement un nouveau scan Nmap.

.....

Un nouveau scan Nmap a été réalisé après sécurisation. Les services inutiles précédemment détectés n'étaient plus accessibles, confirmant la réduction de la surface d'exposition du serveur.

> Diagnostic : le scan Nmap initial montrait des services inutiles exposés (HTTP/80, SMTP/25) susceptibles d'être exploités lors d'une phase de reconnaissance. La fermeture de ces ports au profit du HTTPS et la limitation des informations divulguées par Apache réduisent fortement la surface d'attaque du serveur.

Attaque n°8 : Vérification des protections SSH

Les protections mises en place lors de la phase de sécurisation ont été vérifiées : la vulnérabilité initiale n'est plus exploitable.

> Diagnostic : la tentative de brute force SSH avec Hydra et la liste rockyou.txt échoue car l'authentification par mot de passe a été désactivée au profit de l'authentification par clé publique. Aucun compte ne peut donc être compromis par force brute.

Attaque n°9 : Vérification des protections FTP

Les protections mises en place lors de la phase de sécurisation ont été vérifiées : la vulnérabilité initiale n'est plus exploitable.

> Diagnostic : la tentative de brute force FTP échoue car le protocole FTP en clair a été désactivé au profit du FTPS. Le serveur refuse toute connexion non chiffrée, rendant l'attaque impossible.

Attaque n°10 : Vérification de l'accès root SSH

Les protections mises en place lors de la phase de sécurisation ont été vérifiées : la vulnérabilité initiale n'est plus exploitable.

> Diagnostic : la connexion directe au compte root est refusée par le serveur grâce à la directive PermitRootLogin no du fichier sshd_config. Un attaquant ne peut donc pas viser directement le compte le plus privilégié.

Attaque n°11 : Vérification du chiffrement des communications

Les protections mises en place lors de la phase de sécurisation ont été vérifiées : la vulnérabilité initiale n'est plus exploitable.

> Diagnostic : l'analyse Wireshark et les tests curl confirment que les communications HTTPS et FTPS transitent bien via TLS. Les connexions non chiffrées sont refusées, et même l'erreur de certificat affichée par curl prouve que la connexion ne s'établit pas sans certificat reconnu : la confidentialité des données est garantie.

Attaque n°12 : Accès SYSVOL via SMB

Une nouvelle consultation du fichier GptTmpl.inf a permis de vérifier la prise en compte des nouvelles règles de sécurité dans le domaine.

Bien que l'accès à SYSVOL reste autorisé aux utilisateurs authentifiés, les informations récupérées ne révèlent plus une politique de sécurité facilement exploitable.

> Diagnostic : un compte standard pouvait lire le partage SYSVOL et y découvrir, via le fichier GptTmpl.inf, une politique de mots de passe trop faible. Le renforcement de la GPO (longueur minimale, verrouillage de compte) et la désactivation de l'énumération anonyme limitent désormais l'information exploitable par un attaquant.

Attaque n°13 : SYN Flooding

Une nouvelle attaque a été réalisée après l'activation du mécanisme de protection afin de vérifier son efficacité.

Ici la réattaque

Nouvelle attaque

Le trafic excessif a été détecté et limité par le commutateur, réduisant considérablement l'impact potentiel de l'attaque sur le réseau.

Diagnostique On a oublié de faire les diagnostique ta importé les vm ?? il a dit ca compte pour bcp de point

> Diagnostic : l'attaque hping3 générait un trafic anormal d'environ 338 Mbps (~40 000 paquets/s), saturant la bande passante et provoquant un déni de service. L'activation du Storm Control sur les ports du commutateur détecte et limite automatiquement ces flux anormaux : l'impact de l'attaque est fortement réduit.

6.2. Diagnostics des services et des équipements

Au-delà des tests d'intrusion, le bon fonctionnement et la sécurisation de l'ensemble des services ont été vérifiés sur chaque équipement. Les analyses ci-dessous résument les contrôles effectués et les conclusions obtenues.

Serveur Windows — Active Directory

L'intégrité du contrôleur de domaine a été vérifiée : le domaine agence4.fr et sa forêt sont correctement déclarés, les rôles FSMO sont attribués au serveur et les tests de diagnostic Active Directory ne remontent aucune erreur. L'annuaire est donc opérationnel et cohérent.

Serveur Windows — DNS

La résolution des noms fonctionne dans les deux sens : les zones de recherche directe et inverse de agence4.fr renvoient les bons enregistrements, et la résolution du nom du serveur comme de son adresse IP est confirmée. Le DNS soutient correctement l'authentification Active Directory.

Serveur Windows — DHCP

L'étendue 192.168.4.0/24 distribue bien les adresses du pool prévu (192.168.4.11 à 192.168.4.253) ainsi que la passerelle et le serveur DNS. Les baux attribués aux postes clients confirment le bon fonctionnement du service.

Serveur Windows — LDAP / LDAPS

Le port LDAP en clair (389) reste accessible en interne tandis que le port sécurisé LDAPS (636) répond correctement, ce qui confirme la disponibilité du chiffrement TLS pour les échanges avec l'annuaire.

Serveur Windows — NTP

La synchronisation horaire du contrôleur de domaine est valide et la source de temps est correctement configurée, garantissant la cohérence temporelle nécessaire à Kerberos et à l'analyse des journaux.

Postes clients

Les postes du LAN obtiennent automatiquement une adresse IP via DHCP, résolvent les noms du domaine agence4.fr et sont bien intégrés au domaine, ce qui valide la chaîne complète DHCP → DNS → Active Directory.

Serveur Linux — Services et réseau

La configuration réseau (adresse statique en DMZ, route par défaut vers le pare-feu, serveurs DNS) est correcte et les services Apache, vsftpd et rsyslog sont actifs. Le serveur est joignable et opérationnel.

Serveur Linux — Ports et chiffrement

L'inventaire des ports ouverts confirme que seuls les services nécessaires et chiffrés sont exposés (HTTPS, FTPS, SMTPS), et la vérification du certificat sur le port 443 confirme la présence d'une connexion TLS valide.

Commutateur Cisco — Segmentation et protections

Les VLAN 10 (LAN) et 20 (DMZ) sont correctement créés et le lien trunk vers le pare-feu est actif. Les mécanismes de sécurité de couche 2 sont opérationnels : Port Security limite les adresses MAC par port, DHCP Snooping filtre les réponses DHCP, Dynamic ARP Inspection contrôle les annonces ARP et Storm Control limite les flux anormaux.

7. Bilan des vulnérabilités et contre-mesures

Le tableau de synthèse ci-dessous récapitule, pour chaque test d'intrusion réalisé, la vulnérabilité identifiée ainsi que la contre-mesure appliquée conformément aux recommandations de l'ANSSI.

Test d'intrusion	Vulnérabilité identifiée	Contre-mesure appliquée
n°1 — Scan Nikto (Web)	En-têtes HTTP de sécurité absents, divulgation d'informations serveur	Ajout des en-têtes HSTS, CSP, X-Frame-Options, etc. et limitation du fingerprinting
n°2 — Énumération LDAP	Annuaire AD interrogeable en clair	Déploiement de LDAPS (TLS sur le port 636)
n°3 — AS-REP Roasting	Compte sans pré-authentification Kerberos	Réactivation de la pré-authentification Kerberos
n°4 — DHCP Rogue	Faux serveur DHCP accepté par les clients	Activation du DHCP Snooping sur le commutateur
n°5 — MAC Flooding	Saturation de la table MAC du switch	Activation du Port Security
n°6 — ARP Spoofing	Man-in-the-Middle par usurpation ARP	Dynamic ARP Inspection + signature SMB
n°7 — Scan Nmap (Linux)	Ports HTTP (80) et SMTP (25) inutiles exposés	Fermeture des ports inutiles, HTTPS uniquement
n°8 — Brute force SSH	Risque d'attaque par dictionnaire	Authentification par clé, mots de passe désactivés
n°9 — Brute force FTP	Transfert de fichiers en clair	FTPS imposé (force_local_logins_ssl)
n°10 — Accès root SSH	Connexion directe au compte root	PermitRootLogin no
n°11 — Chiffrement	Interception possible du trafic	TLS vérifié sur HTTPS et FTPS (Wireshark/curl)
n°12 — Accès SYSVOL	Politique de mot de passe faible, énumération anonyme	Renforcement GPO + désactivation énumération anonyme
n°13 — SYN Flooding	Déni de service (~338 Mbps de trafic anormal)	Activation du Storm Control sur le commutateur

8. Conclusion

Ce projet a permis de déployer puis de sécuriser un système d'information complet, multi-site, intégrant un pare-feu Stormshield, un commutateur Cisco, un serveur Windows Server 2022 (Active Directory) et un serveur Linux hébergeant plusieurs services exposés en DMZ.

La méthodologie suivie — installation, tests d'intrusion, sécurisation, puis nouveaux tests d'intrusion — a permis de mettre en évidence des vulnérabilités concrètes (absence de chiffrement, comptes par défaut, énumération AD, déni de service, ARP spoofing, MAC flooding, etc.) puis de démontrer l'efficacité des contre-mesures appliquées, conformément aux recommandations de l'ANSSI.

Au terme de ce projet, l'ensemble des services de l'infrastructure (Web, messagerie, transfert de fichiers, annuaire, DNS, DHCP) est opérationnel et sécurisé : les communications sont chiffrées (HTTPS, FTPS, SMTPS, LDAPS), les accès distants durcis (SSH par clé, interdiction du root), et le commutateur protégé contre les attaques de couche 2 (Port Security, DHCP Snooping, Dynamic ARP Inspection, Storm Control). Le système d'information répond ainsi aux objectifs de sécurité fixés par le sujet.